

Rapport Mise en œuvre d'un serveur KERBEROS

Mehdi MSALLEM

MS CYBER2 – Janvier 2026

Encadrant Académique

Thomas Robert



Table des matières

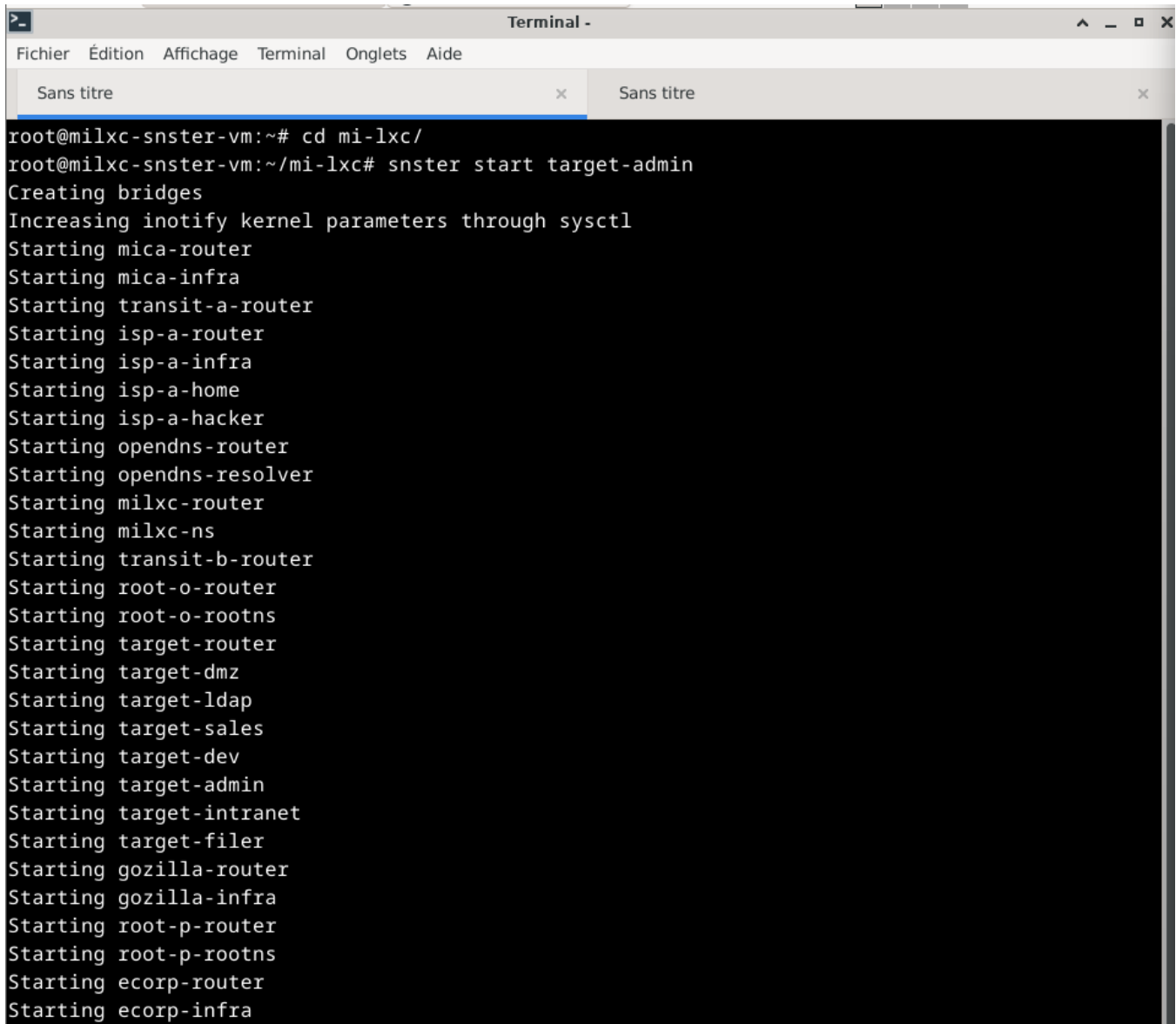
1. Préparation de l'environnement.....	3
2. Configuration du KDC	7
3. Configuration d'un serveur SSH sur la VM target-dmz	17
4. Configuration d'un client Kerberos sur une nouvelle VM.....	21
5. Test & Troubleshooting.....	22
6. Analyse des Messages Kerberos Wireshark	26

Table des figures

Figure 1 - Lancement VM target-admin.....	3
Figure 2 - Lancement VM target-dmz.....	4
Figure 3 - interconnexion entre les VMs et vérification des adresses IP.....	5
Figure 4 - Configuration de la DNS locale	6
Figure 5 - Realm par défaut	7
Figure 6 - Kerberos Server Hostname	7
Figure 7 - Kerberos Admin Server Hostname	7
Figure 8 - Initialisation de DB & création de mot de passe.....	8
Figure 9 - Création de l'administrateur	9
Figure 10 - Configuration des droits (ACL)	10
Figure 11 - Création des Principaux & Keytabs	13
Figure 12 - Déploiement du fichier Keytab.....	14
Figure 13 - Activation des Services Kerberos.....	16
Figure 14 - Configuration du service SSH (DMZ-target).....	17
Figure 15 - Installation du fichier Keytab.....	18
Figure 16 - Configuration Kerberos Locale	19
Figure 17 - Configuration Kerberos Locale 2	20
Figure 18 - Configuration Client (target-sales).....	21
Figure 19 - Résolution des noms (DNS)	22
Figure 20 - Configuration du client SSH	23
Figure 21 - Obtention du TGT	24
Figure 22 - Connection au service	25
Figure 23 - Capture des message Kerberos Wireshark.....	26
Figure 24 - L'analyse des messages Kerberos Wireshark	27

1. Préparation de l'environnement

Les captures d'écran suivantes illustrent ce qu'on vient de préparer nos VMs pour le travail.

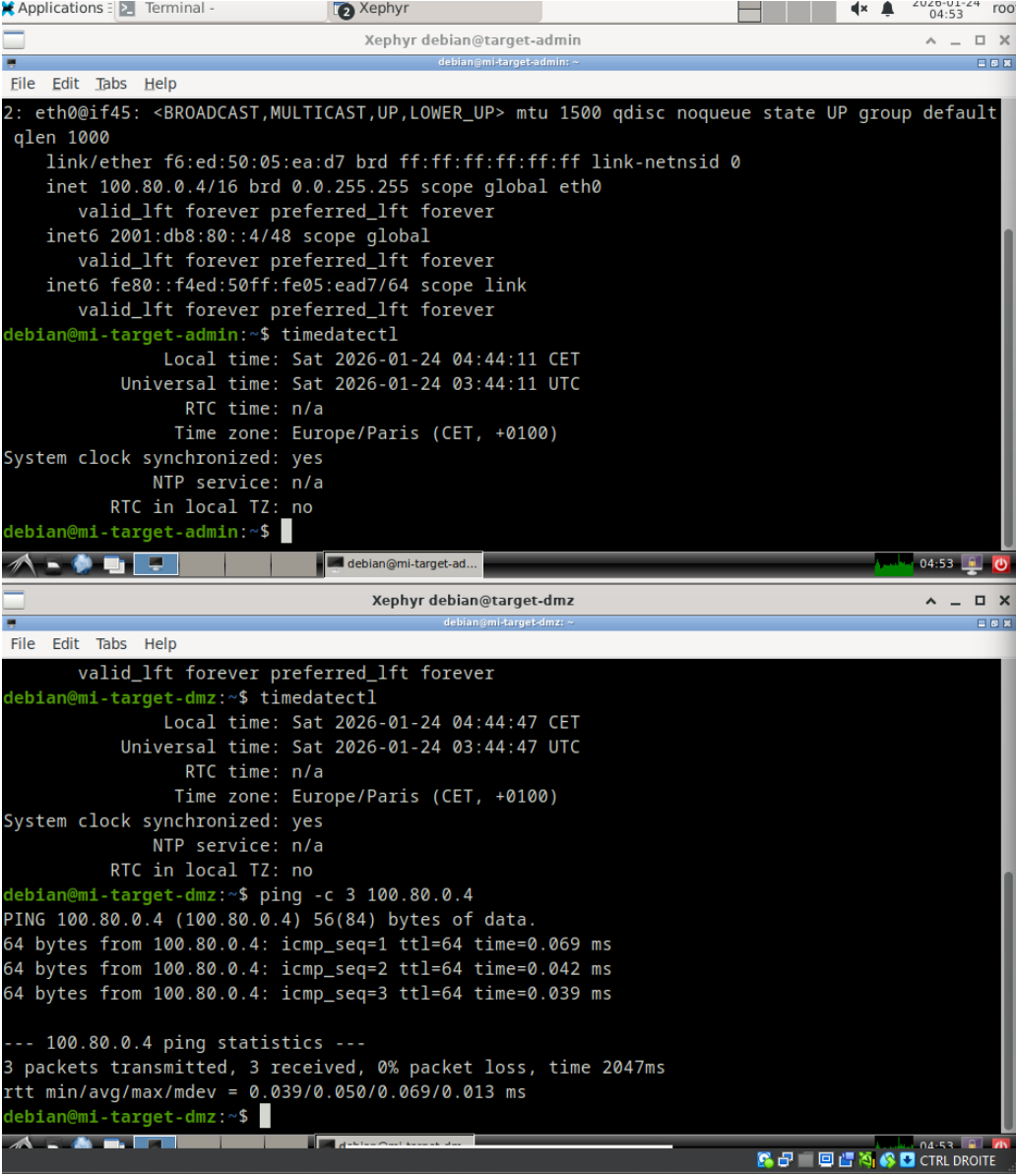


```
Terminal -
Fichier  Édition  Affichage  Terminal  Onglets  Aide
Sans titre x Sans titre x
root@milxc-snster-vm:~# cd mi-lxc/
root@milxc-snster-vm:~/mi-lxc# snster start target-admin
Creating bridges
Increasing inotify kernel parameters through sysctl
Starting mica-router
Starting mica-infra
Starting transit-a-router
Starting isp-a-router
Starting isp-a-infra
Starting isp-a-home
Starting isp-a-hacker
Starting opendns-router
Starting opendns-resolver
Starting milxc-router
Starting milxc-ns
Starting transit-b-router
Starting root-o-router
Starting root-o-rootns
Starting target-router
Starting target-dmz
Starting target-ldap
Starting target-sales
Starting target-dev
Starting target-admin
Starting target-intranet
Starting target-filer
Starting gozilla-router
Starting gozilla-infra
Starting root-p-router
Starting root-p-rootns
Starting ecorp-router
Starting ecorp-infra
```

Figure 1 - Lancement VM target-admin

```
Sans titre x Sans titre x
root@milxc-snster-vm:~/mi-lxc# snster start target-dmz
Creating bridges
device mi-opendns-lan already exists; can't create bridge with the same name
device mi-ecorp-lan already exists; can't create bridge with the same name
device mi-root-p-lan already exists; can't create bridge with the same name
device mi-target-lan already exists; can't create bridge with the same name
device mi-gozilla-lan already exists; can't create bridge with the same name
device mi-transit-a already exists; can't create bridge with the same name
device mi-isp-a-infra already exists; can't create bridge with the same name
device mi-isp-a-cust already exists; can't create bridge with the same name
device mi-root-o-lan already exists; can't create bridge with the same name
device mi-transit-b already exists; can't create bridge with the same name
device mi-milxc-lan already exists; can't create bridge with the same name
device mi-mica-lan already exists; can't create bridge with the same name
Increasing inotify kernel parameters through sysctl
Starting gozilla-router
Starting gozilla-infra
Starting root-o-router
Starting root-o-rootns
Starting root-p-router
Starting root-p-rootns
Starting transit-b-router
Starting milxc-router
Starting milxc-ns
Starting isp-a-router
Starting isp-a-infra
Starting isp-a-home
Starting isp-a-hacker
Starting transit-a-router
Starting opendns-router
Starting opendns-resolver
Starting mica-router
Starting mica-infra
Starting ecorp-router
Starting ecorp-infra
Starting target-router
Starting target-dmz
Starting target-ldap
Starting target-sales
Starting target-dev
Starting target-admin
```

Figure 2 - Lancement VM target-dmz



The image shows two terminal windows from a desktop environment. The top window is titled 'Xephyr debian@target-admin' and shows the output of the 'ifconfig' command for the 'eth0' interface, displaying IP addresses 100.80.0.4/16 and 100.80.0.4/48. It also shows the output of 'timedatectl', indicating the system clock is synchronized and the time zone is Europe/Paris (CET, +0100). The bottom window is titled 'Xephyr debian@target-dmz' and shows the output of 'timedatectl' (same as the top window) and a 'ping -c 3 100.80.0.4' command. The ping results show successful connections with 0% packet loss and round-trip times around 0.039ms to 0.069ms.

```
Xephyr debian@target-admin
debian@mi-target-admin: ~$ ifconfig
2: eth0@if45: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
qlen 1000
    link/ether f6:ed:50:05:ea:d7 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 100.80.0.4/16 brd 0.0.255.255 scope global eth0
        valid_lft forever preferred_lft forever
    inet6 2001:db8:80::4/48 scope global
        valid_lft forever preferred_lft forever
    inet6 fe80::f4ed:50ff:fe05:ead7/64 scope link
        valid_lft forever preferred_lft forever
debian@mi-target-admin:~$ timedatectl
    Local time: Sat 2026-01-24 04:44:11 CET
    Universal time: Sat 2026-01-24 03:44:11 UTC
    RTC time: n/a
    Time zone: Europe/Paris (CET, +0100)
System clock synchronized: yes
    NTP service: n/a
    RTC in local TZ: no
debian@mi-target-admin:~$

Xephyr debian@target-dmz
debian@mi-target-dmz: ~$ timedatectl
    Local time: Sat 2026-01-24 04:44:47 CET
    Universal time: Sat 2026-01-24 03:44:47 UTC
    RTC time: n/a
    Time zone: Europe/Paris (CET, +0100)
System clock synchronized: yes
    NTP service: n/a
    RTC in local TZ: no
debian@mi-target-dmz:~$ ping -c 3 100.80.0.4
PING 100.80.0.4 (100.80.0.4) 56(84) bytes of data:
64 bytes from 100.80.0.4: icmp_seq=1 ttl=64 time=0.069 ms
64 bytes from 100.80.0.4: icmp_seq=2 ttl=64 time=0.042 ms
64 bytes from 100.80.0.4: icmp_seq=3 ttl=64 time=0.039 ms

--- 100.80.0.4 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2047ms
rtt min/avg/max/mdev = 0.039/0.050/0.069/0.013 ms
debian@mi-target-dmz:~$
```

Figure 3 - interconnexion entre les VMs et vérification des adresses IP

Dans cette capture, on constate qu'on a déjà établi la connexion entre **target-admin** & **target-dmz**. Comme montré dessus, les adresses IP pour ces deux machines sont les suivants :

- **target-admin** : 100.80.0.4
- **target-dmz** : 100.80.1.2

The image shows two terminal windows side-by-side, both running GNU nano 7.2 and editing the /etc/hosts file. The top window is titled 'Xephyr debian@target-admin' and the bottom window is titled 'Xephyr debian@target-dmz'. Both windows show the same content in the /etc/hosts file:

```
# The following lines are desirable for IPv6 capable hosts
::1    localhost ip6-localhost ip6-loopback
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters

100.80.0.4    mykdc.telecom.com        mykdc
100.80.0.4    mykdc-admin.telecom.com            mykdc-admin
100.80.1.2    ssh-server.telecom.com            ssh-server
100.80.1.2    apache-server.telecom.com        apache-server
100.80.1.2    ftp-server.telecom.com            ftp-server
```

The bottom window also has an additional line at the top: 127.0.1.1 lxc-infra-dmz.

Figure 4 - Configuration de la DNS locale

Comme nous n'avons pas de vrai serveur DNS, nous allons dire manuellement aux machines qui est qui. Par suite, on a ajouté et établi les adresses IP pour chaque machine et service.

2. Configuration du KDC

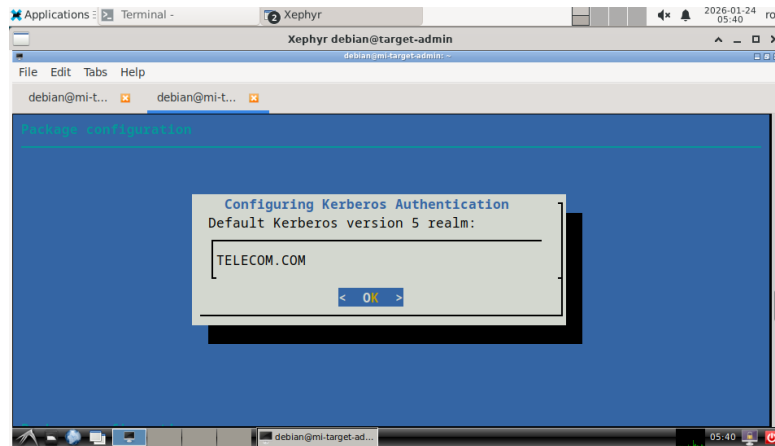


Figure 5 - Realm par défaut

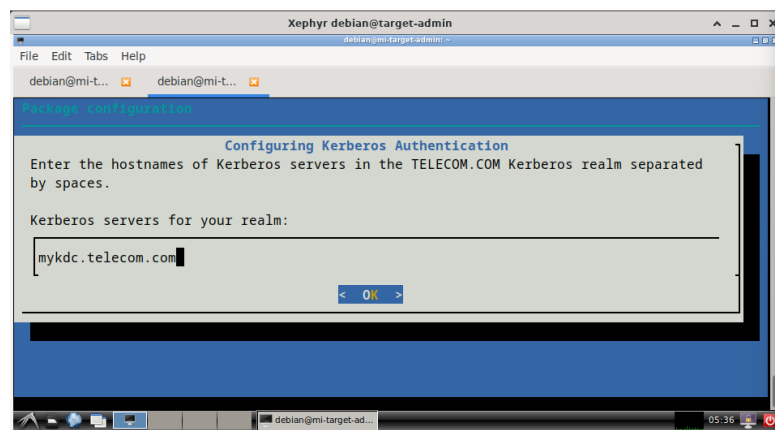


Figure 6 - Kerberos Server Hostname

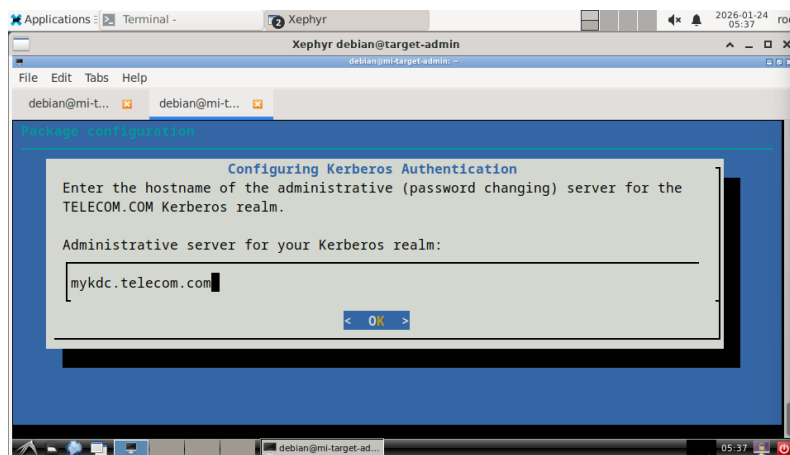
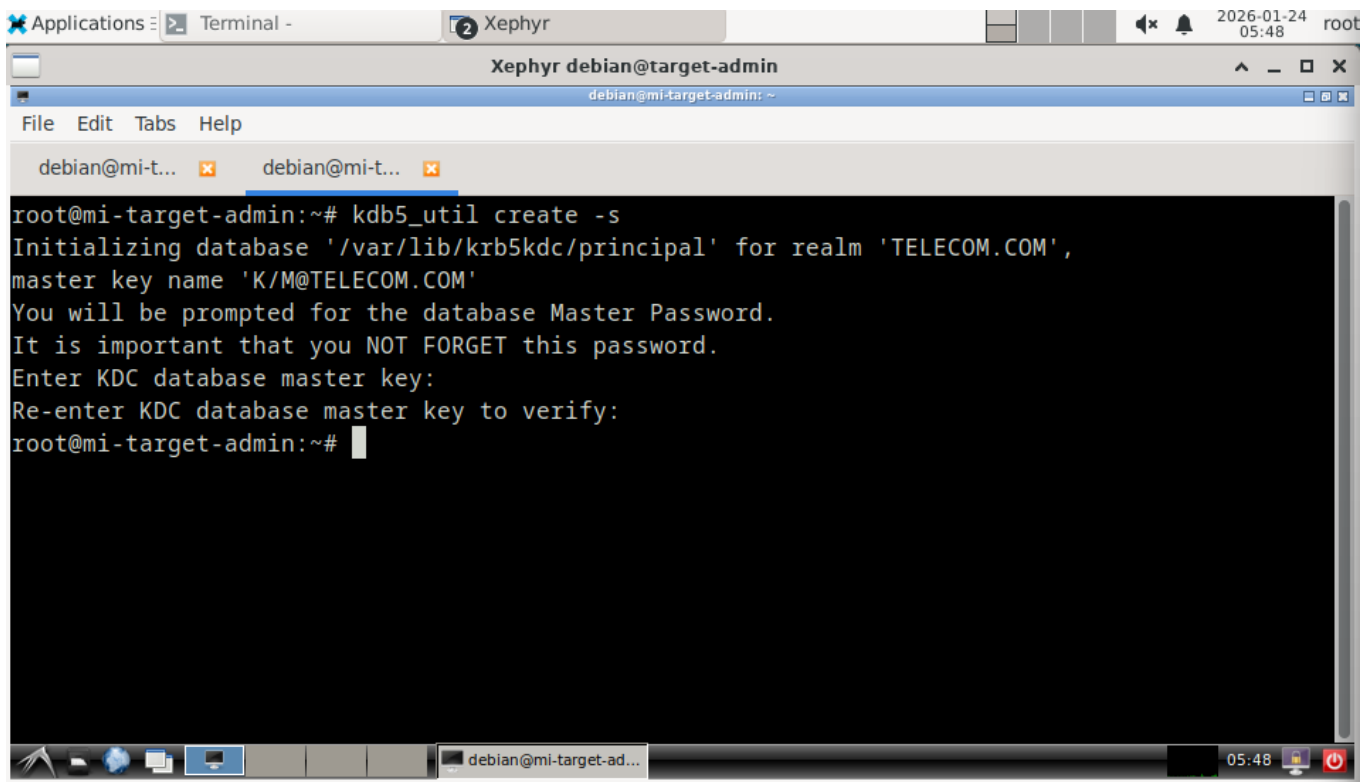


Figure 7 - Kerberos Admin Server Hostname

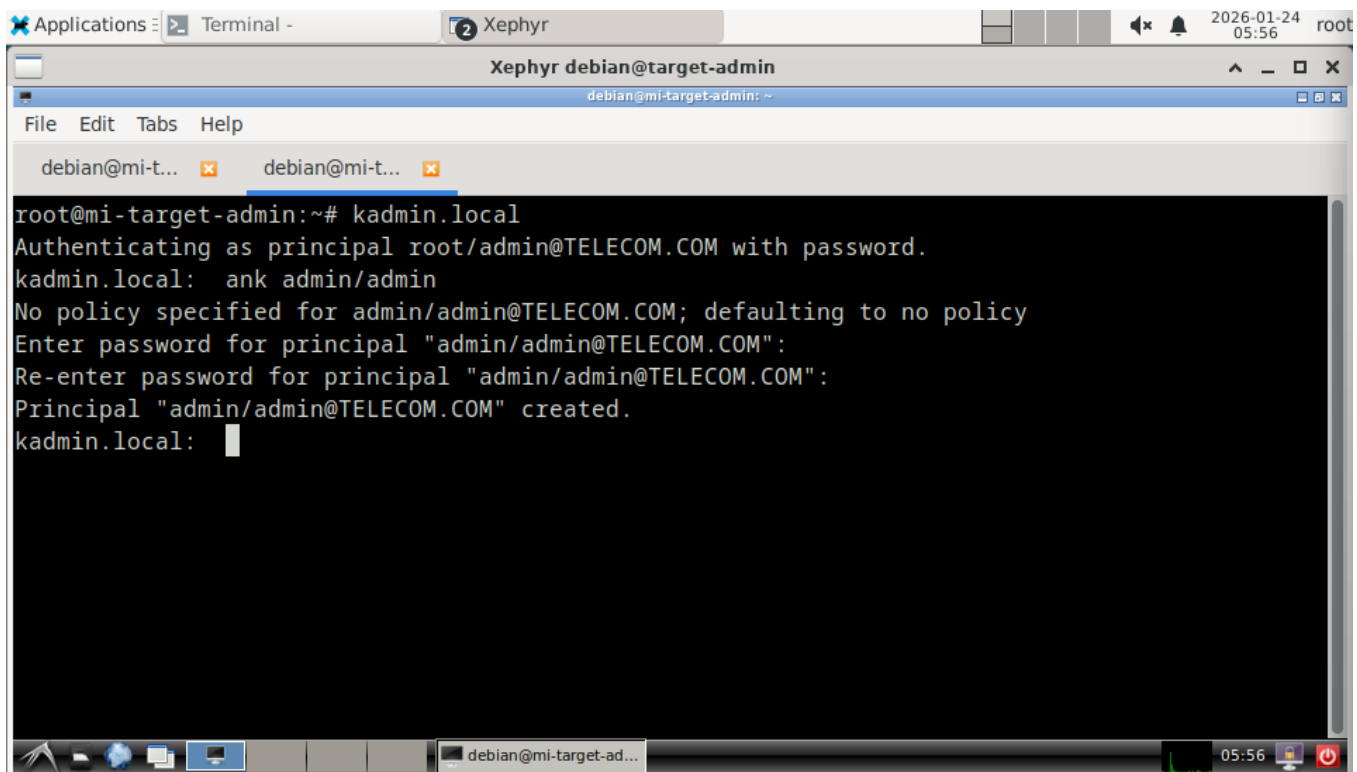


The screenshot shows a terminal window titled 'Xephyr' with the user 'debian@mi-target-admin'. The terminal output shows the execution of the command 'kdb5_util create -s' to initialize a Kerberos database. The output indicates that the database is being created for the realm 'TELECOM.COM' with a master key name 'K/M@TELECOM.COM'. It prompts the user to enter the database master key and to re-enter it for verification. The user has entered a password, and the terminal shows a cursor at the end of the line 'root@mi-target-admin:~# '.

```
root@mi-target-admin:~# kdb5_util create -s
Initializing database '/var/lib/krb5kdc/principal' for realm 'TELECOM.COM',
master key name 'K/M@TELECOM.COM'
You will be prompted for the database Master Password.
It is important that you NOT FORGET this password.
Enter KDC database master key:
Re-enter KDC database master key to verify:
root@mi-target-admin:~#
```

Figure 8 - Initialisation de DB & création de mot de passe

Création du stash file : L'exécution de la commande **kdb5_util create -s** a permis de générer la base de données principale des principaux Kerberos. L'option -s crée un "stash file" qui stocke la clé maîtresse (Master Key) localement, permettant au service KDC de démarrer automatiquement sans intervention humaine pour saisir le mot de passe à chaque redémarrage.



```
Applications | Terminal - | Xephyr | 2026-01-24 05:56 root
Xephyr debian@target-admin
debian@mi-target-admin: ~
File Edit Tabs Help
debian@mi-t... x debian@mi-t... x
root@mi-target-admin:~# kadmin.local
Authenticating as principal root/admin@TELECOM.COM with password.
kadmin.local: ank admin/admin
No policy specified for admin/admin@TELECOM.COM; defaulting to no policy
Enter password for principal "admin/admin@TELECOM.COM":
Re-enter password for principal "admin/admin@TELECOM.COM":
Principal "admin/admin@TELECOM.COM" created.
kadmin.local: 
```

Figure 9 - Création de l'administrateur

Création du principal d'administration : Via l'interface **kadmin.local** (qui permet d'accéder à la base directement sur le fichier local sans passer par le réseau), nous avons créé le principal **admin/admin**. C'est le compte qui sera utilisé pour ajouter ultérieurement les utilisateurs (SSH, FTP) dans la base.

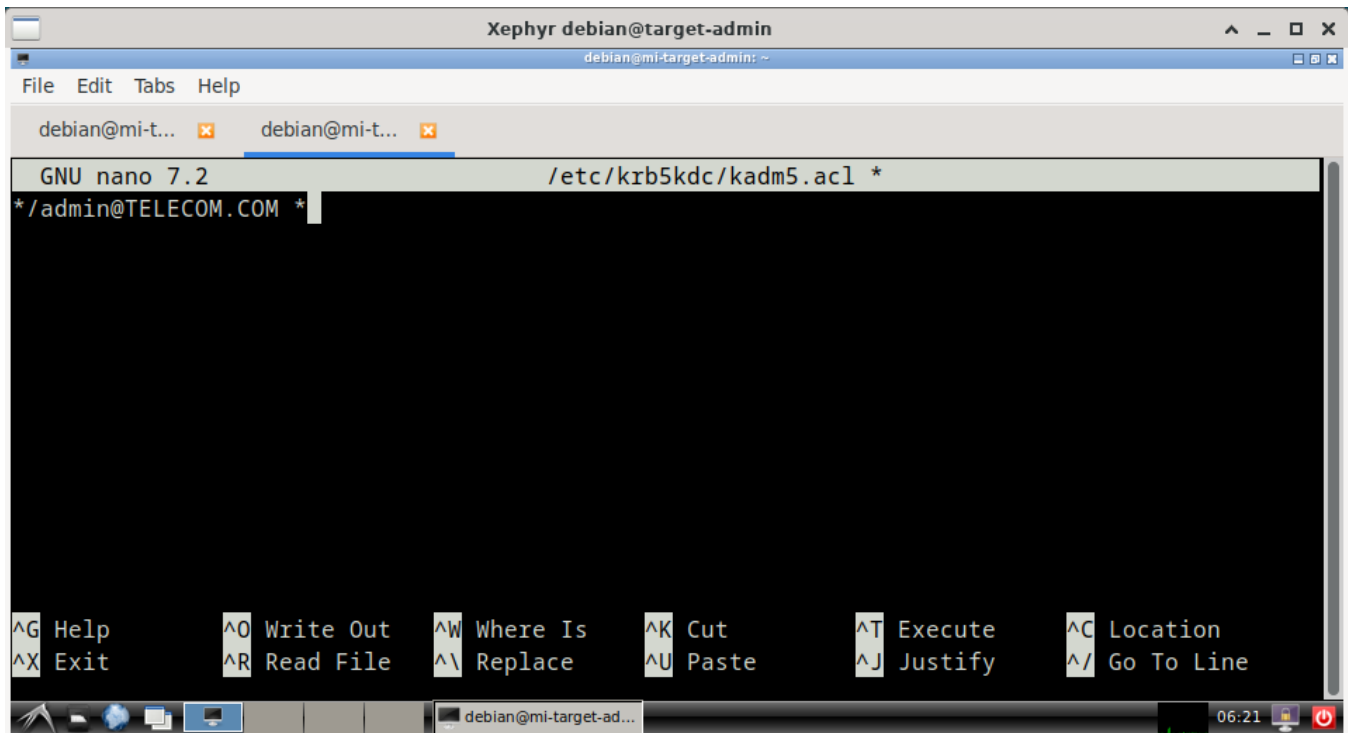
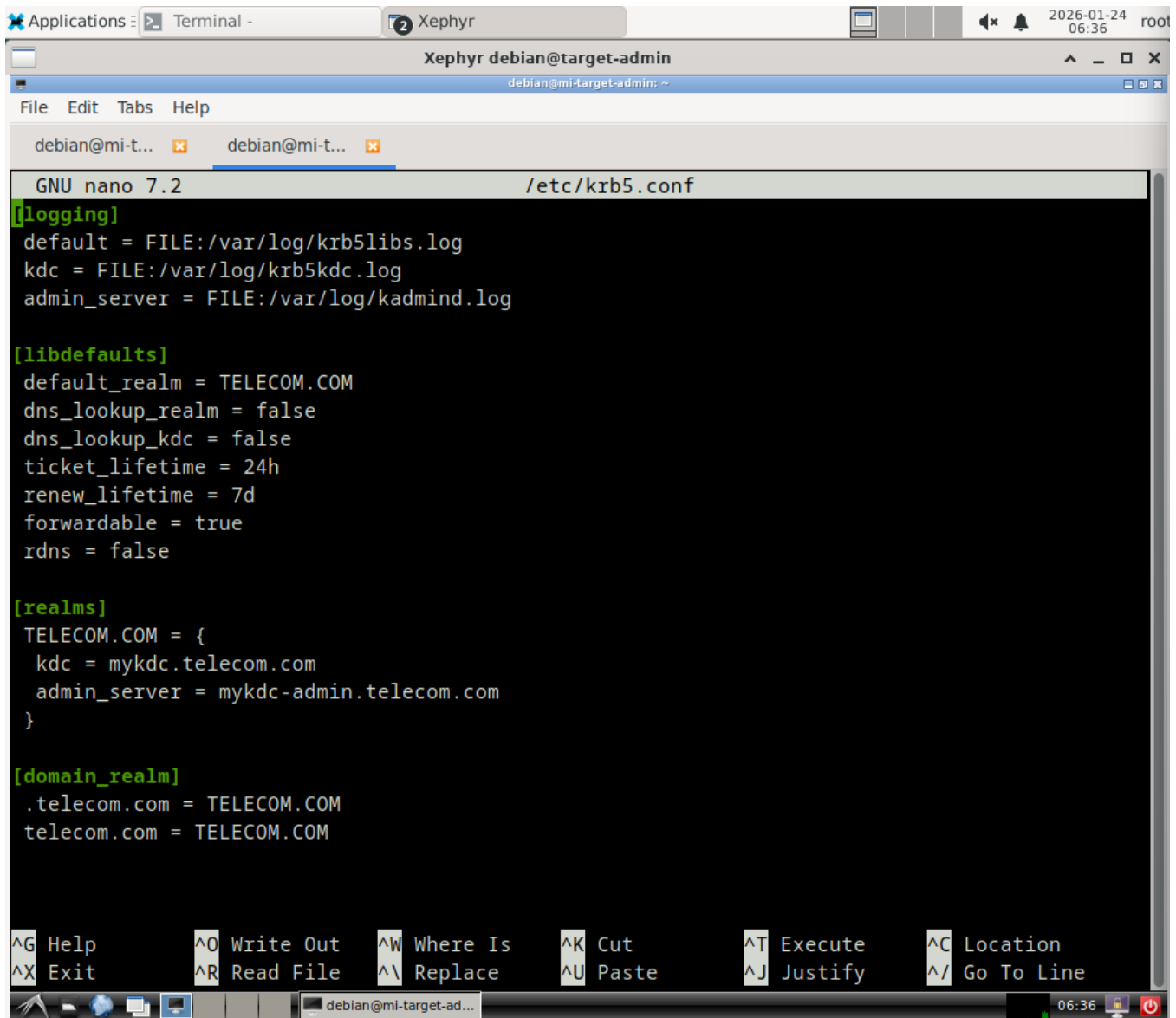


Figure 10 - Configuration des droits (ACL)

- */admin@TELECOM.COM : Désigne n'importe quel utilisateur (*) qui possède l'instance admin dans le royaume TELECOM.COM.
- * (à la fin) : Lui donne **tous** les droits (créer, supprimer, modifier des tickets).



The screenshot shows a terminal window titled 'Xephyr debian@target-admin'. The user is editing the file '/etc/krb5.conf' using the 'GNU nano 7.2' editor. The configuration is as follows:

```
[logging]
default = FILE:/var/log/krb5libs.log
kdc = FILE:/var/log/krb5kdc.log
admin_server = FILE:/var/log/kadmind.log

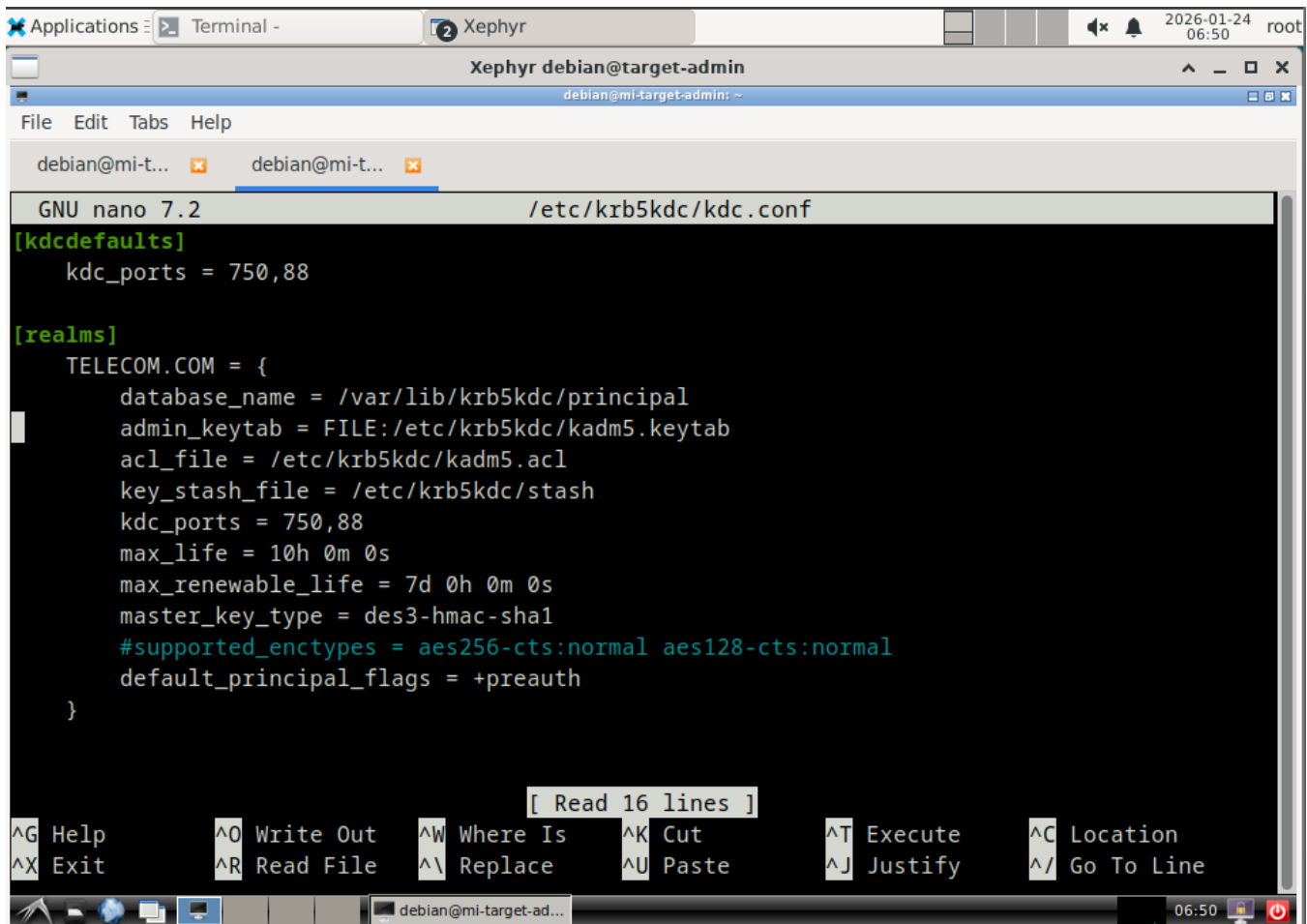
[libdefaults]
default_realm = TELECOM.COM
dns_lookup_realm = false
dns_lookup_kdc = false
ticket_lifetime = 24h
renew_lifetime = 7d
forwardable = true
rdns = false

[realms]
TELECOM.COM = {
  kdc = mykdc.telecom.com
  admin_server = mykdc-admin.telecom.com
}

[domain_realm]
.telecom.com = TELECOM.COM
telecom.com = TELECOM.COM
```

The terminal window also shows a status bar at the bottom with various keyboard shortcuts like ^G Help, ^O Write Out, ^W Where Is, ^K Cut, ^T Execute, ^C Location, ^X Exit, ^R Read File, ^_ Replace, ^U Paste, ^J Justify, and ^/ Go To Line.

Fichier /etc/krb5.conf : Ce fichier définit les paramètres par défaut pour le royaume. Nous avons défini **TELECOM.COM** comme royaume par défaut et configuré le mapping de domaine (**[domain realm]**) pour que tout hôte finissant par **.telecom.com** soit associé à ce royaume. Les logs ont été redirigés vers **/var/log/** pour faciliter le débogage.

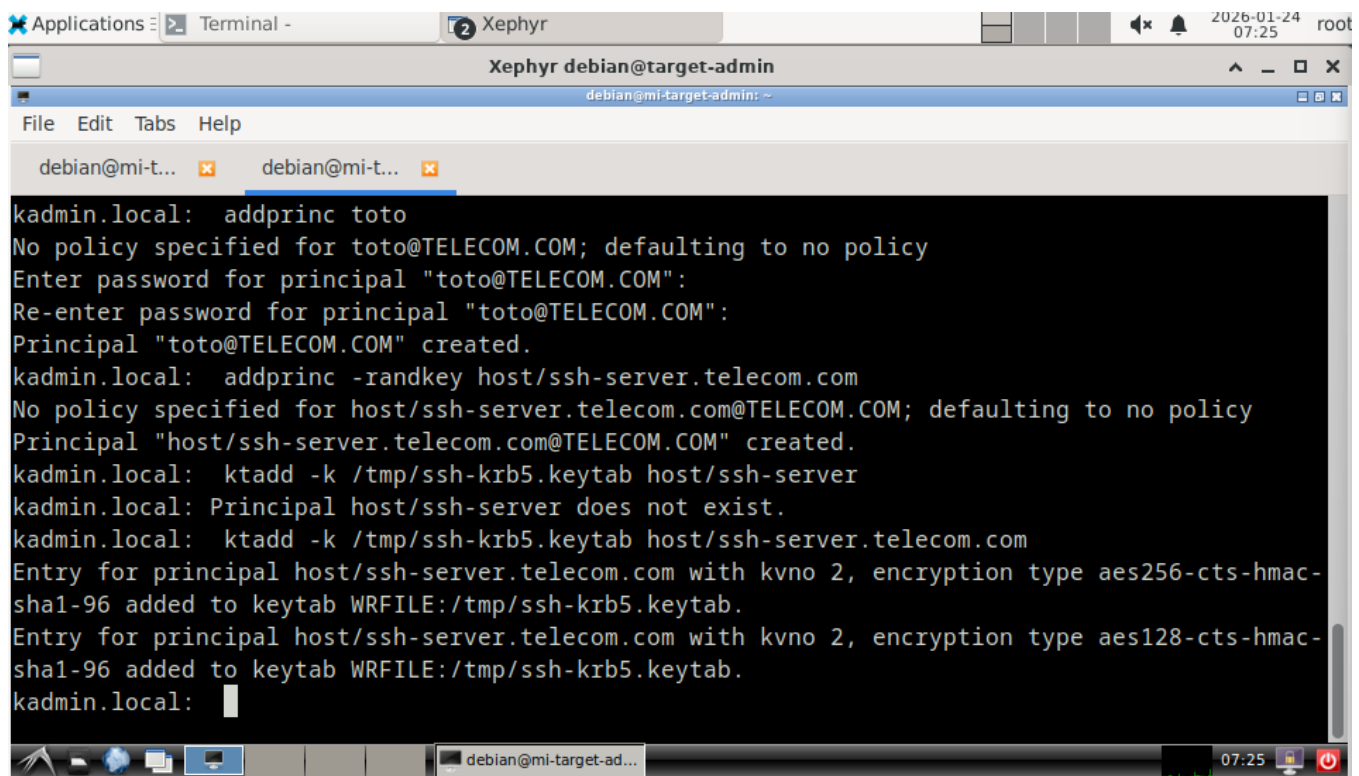


```
Applications: Terminal - Xephyr 2026-01-24 06:50 root
Xephyr debian@target-admin
debian@mi-target-admin: ~
File Edit Tabs Help
debian@mi-t... x debian@mi-t... x
GNU nano 7.2 /etc/krb5kdc/kdc.conf
[kdcdefaults]
    kdc_ports = 750,88

[realms]
    TELECOM.COM = {
        database_name = /var/lib/krb5kdc/principal
        admin_keytab = FILE:/etc/krb5kdc/kadm5.keytab
        acl_file = /etc/krb5kdc/kadm5.acl
        key_stash_file = /etc/krb5kdc/stash
        kdc_ports = 750,88
        max_life = 10h 0m 0s
        max_renewable_life = 7d 0h 0m 0s
        master_key_type = des3-hmac-sha1
        #supported_enctypes = aes256-cts:normal aes128-cts:normal
        default_principal_flags = +preauth
    }

[ Read 16 lines ]
^G Help      ^O Write Out ^W Where Is  ^K Cut       ^T Execute   ^C Location
^X Exit      ^R Read File ^\ Replace   ^U Paste     ^J Justify   ^_ Go To Line
```

Fichier `/etc/krb5kdc/kdc.conf` : Ce fichier configure le comportement interne du KDC. Nous avons spécifié l'emplacement de la base de données (*`/var/lib/krb5kdc/principal`*), du fichier ACL que nous avons créé, et défini les durées de vie maximales des tickets (*`max life` à 10h*).



```
kadmin.local: addprinc toto
No policy specified for toto@TELECOM.COM; defaulting to no policy
Enter password for principal "toto@TELECOM.COM":
Re-enter password for principal "toto@TELECOM.COM":
Principal "toto@TELECOM.COM" created.
kadmin.local: addprinc -randkey host/ssh-server.telecom.com
No policy specified for host/ssh-server.telecom.com@TELECOM.COM; defaulting to no policy
Principal "host/ssh-server.telecom.com@TELECOM.COM" created.
kadmin.local: ktadd -k /tmp/ssh-krb5.keytab host/ssh-server
kadmin.local: Principal host/ssh-server does not exist.
kadmin.local: ktadd -k /tmp/ssh-krb5.keytab host/ssh-server.telecom.com
Entry for principal host/ssh-server.telecom.com with kvno 2, encryption type aes256-cts-hmac-sha1-96 added to keytab WRFILE:/tmp/ssh-krb5.keytab.
Entry for principal host/ssh-server.telecom.com with kvno 2, encryption type aes128-cts-hmac-sha1-96 added to keytab WRFILE:/tmp/ssh-krb5.keytab.
kadmin.local:
```

Figure 11 - Création des Principaux & Keytabs

Une fois le KDC configuré, nous avons peuplé la base de données avec les identités nécessaires au scénario :

- **Principal Utilisateur (*toto*)** : Créé via ***addprinc toto***. Ce compte servira à simuler un client humain demandant l'accès aux services.
- **Principal Service (*host/ssh-server.telecom.com*)** : Créé via ***addprinc -randkey***. L'option ***-randkey*** génère une clé aléatoire car ce compte est destiné à une machine (Service), qui ne saisit pas de mot de passe manuellement.

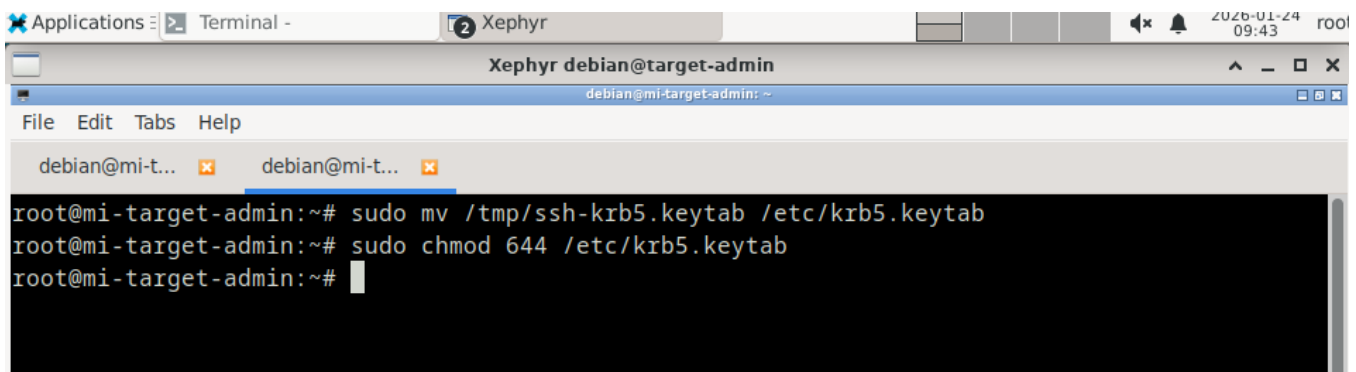
Exportation de la Keytab : La commande ***ktadd*** a été utilisée pour extraire les clés cryptographiques du principal de service dans un fichier ***/tmp/ssh-krb5.keytab***. Ce fichier, appelé "keytab" (Key Table), agit comme le mot de passe du serveur SSH. Il permet au serveur de déchiffrer les tickets qui lui sont présentés sans intervention humaine.

Le problème de sécurité : Le dossier */tmp* est souvent accessible en lecture par tous les utilisateurs du système, et son contenu est effacé au redémarrage.

La recommandation : Dans un environnement de production, il faut préciser que ce fichier doit être déplacé dans un dossier protégé (comme */etc/*) et que le chemin dans la configuration SSH (*sshd_config*) devra être adapté en conséquence.

Le fichier .keytab contient les clés de chiffrement équivalentes à un mot de passe.

- **La vigilance :** Si un utilisateur malveillant copie ce fichier, il peut se faire passer pour le serveur ssh-server.
- **La bonne pratique :** Il faut restreindre les droits d'accès après la création :
 - Appartenance : root:root
 - Droits : 600 (lecture/écriture uniquement pour le propriétaire).



The screenshot shows a terminal window titled 'Xephyr' with the user 'debian@mi-target-admin'. The terminal displays the following commands and output:

```
root@mi-target-admin:~# sudo mv /tmp/ssh-krb5.keytab /etc/krb5.keytab
root@mi-target-admin:~# sudo chmod 644 /etc/krb5.keytab
root@mi-target-admin:~#
```

Figure 12 - Déploiement du fichier Keytab

Nous avons créé deux principaux dans la base Kerberos :

- **Utilisateur :** *toto@TELECOM.COM* (avec mot de passe).
- **Service :** *host/ssh-server.telecom.com@TELECOM.COM* (avec l'option *-randkey* pour une sécurité maximale, évitant l'usage d'un mot de passe manuel pour le service).

Nous avons exporté les clés du service dans un fichier local sur le serveur d'administration :

ktadd -k /tmp/ssh-krb5.keytab host/ssh-server.telecom.com

Note technique : Lors de la première tentative, l'omission du nom de domaine (FQDN) a provoqué une erreur. Kerberos nécessite impérativement le nom complet de la machine (**.telecom.com**)

L'énoncé suggérait un transfert via l'utilisateur **toto** vers le dossier **/tmp**. Cependant, en l'absence de compte local **toto** fonctionnel sur le serveur cible, nous avons opté pour un transfert direct via le compte administrateur **root**.

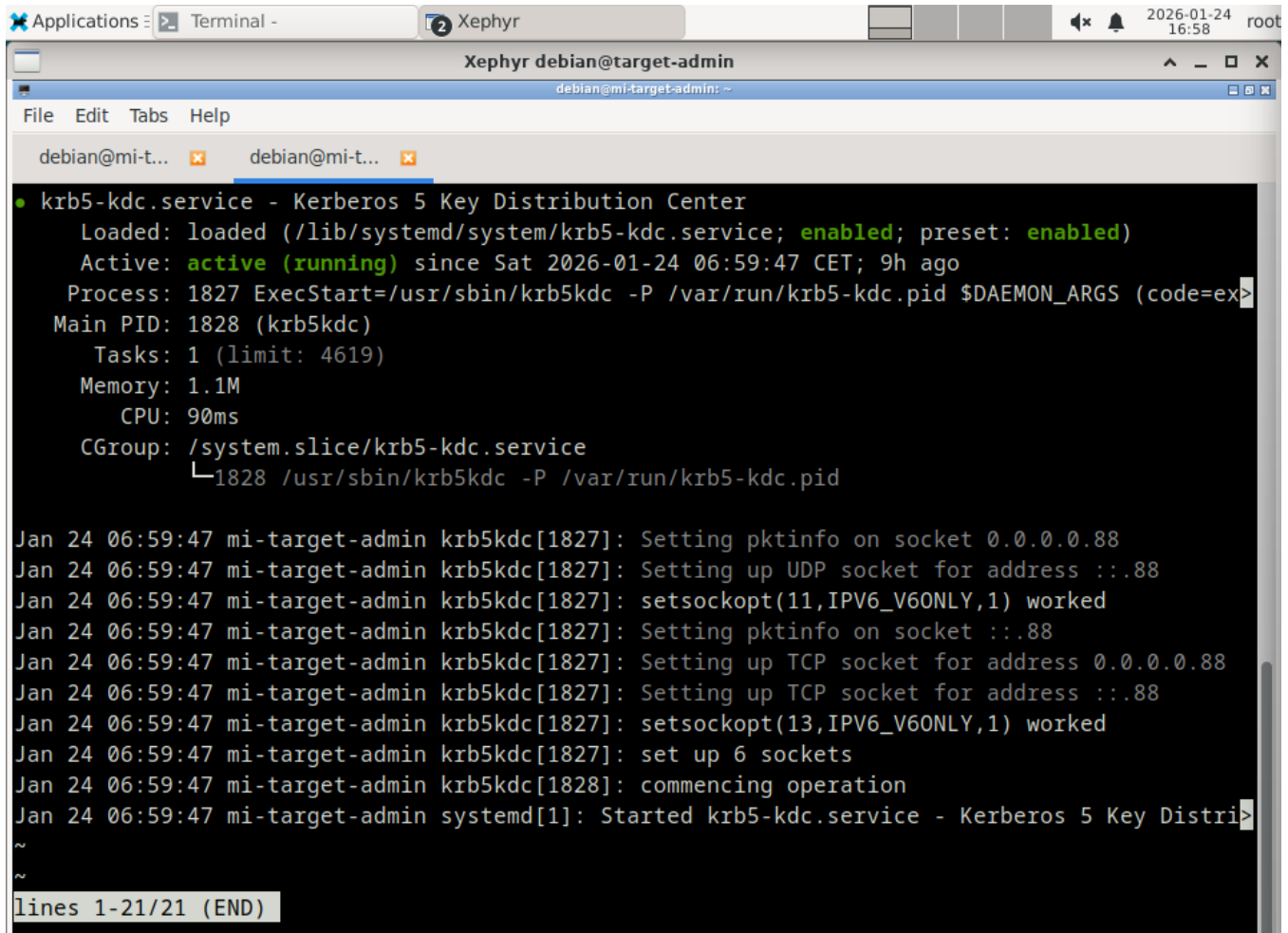
Nous avons d'abord identifié l'adresse IP du serveur via la commande **ping** : **100.80.1.2**.

Commande exécutée (depuis le shell système, après avoir quitté **kadmin**) :

```
scp /tmp/ssh-krb5.keytab root@100.80.1.2:/etc/krb5.keytab
```

Comme nous avons transféré le fichier directement dans **/etc/krb5.keytab** via le compte **root**, l'étape de déplacement (**mv**) décrite dans le sujet est devenue superflue.

```
chmod 644 /etc/krb5.keytab
```



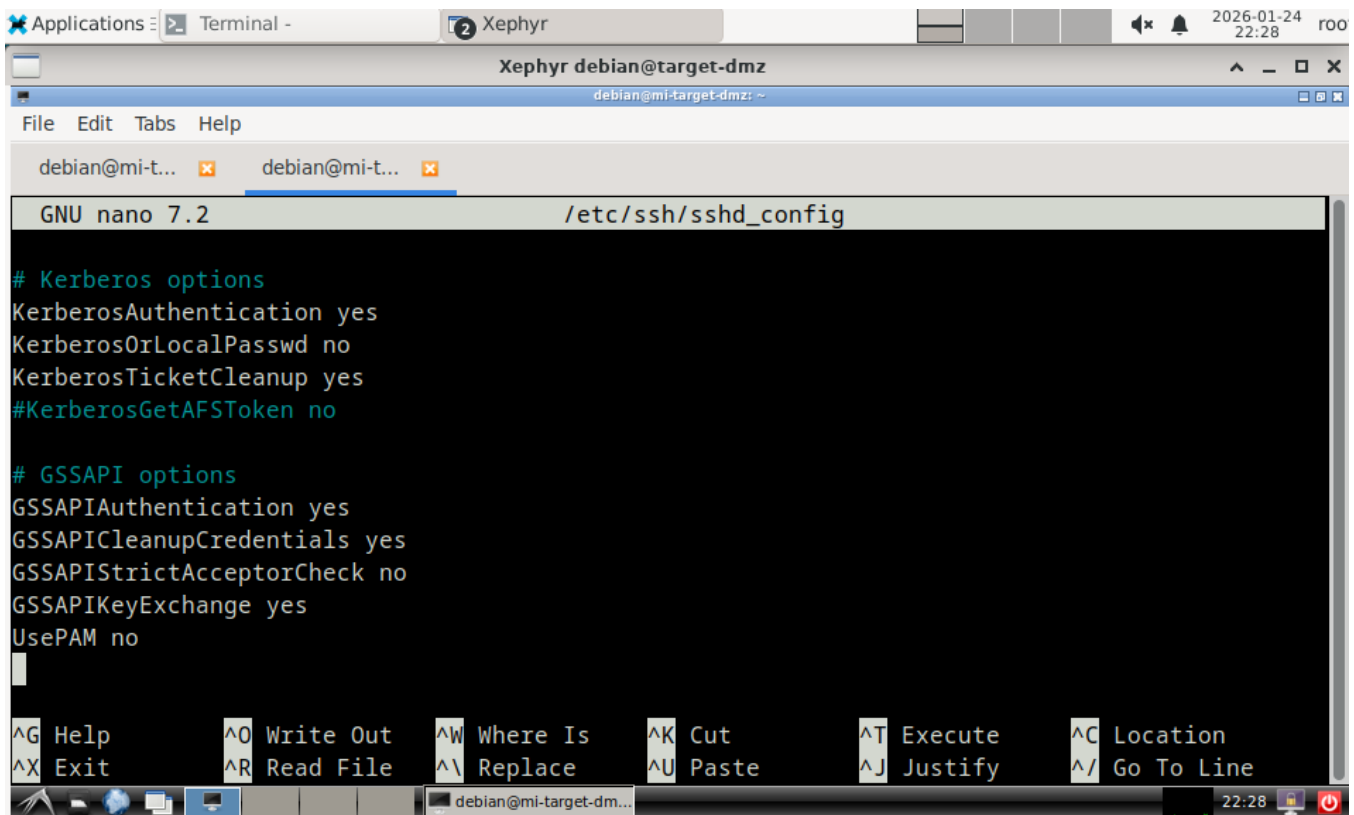
```
Applications ▾ Terminal - Xephyr 2026-01-24 16:58 root
Xephyr debian@target-admin
debian@mi-target-admin: ~
File Edit Tabs Help
debian@mi-t... x debian@mi-t... x
• krb5-kdc.service - Kerberos 5 Key Distribution Center
  Loaded: loaded (/lib/systemd/system/krb5-kdc.service; enabled; preset: enabled)
  Active: active (running) since Sat 2026-01-24 06:59:47 CET; 9h ago
  Process: 1827 ExecStart=/usr/sbin/krb5kdc -P /var/run/krb5-kdc.pid $DAEMON_ARGS (code=ex>
  Main PID: 1828 (krb5kdc)
  Tasks: 1 (limit: 4619)
  Memory: 1.1M
  CPU: 90ms
  CGroup: /system.slice/krb5-kdc.service
          └─1828 /usr/sbin/krb5kdc -P /var/run/krb5-kdc.pid

Jan 24 06:59:47 mi-target-admin krb5kdc[1827]: Setting pktinfo on socket 0.0.0.0.88
Jan 24 06:59:47 mi-target-admin krb5kdc[1827]: Setting up UDP socket for address ::.88
Jan 24 06:59:47 mi-target-admin krb5kdc[1827]: setsockopt(11,IPV6_V6ONLY,1) worked
Jan 24 06:59:47 mi-target-admin krb5kdc[1827]: Setting pktinfo on socket ::.88
Jan 24 06:59:47 mi-target-admin krb5kdc[1827]: Setting up TCP socket for address 0.0.0.0.88
Jan 24 06:59:47 mi-target-admin krb5kdc[1827]: Setting up TCP socket for address ::.88
Jan 24 06:59:47 mi-target-admin krb5kdc[1827]: setsockopt(13,IPV6_V6ONLY,1) worked
Jan 24 06:59:47 mi-target-admin krb5kdc[1827]: set up 6 sockets
Jan 24 06:59:47 mi-target-admin krb5kdc[1828]: commencing operation
Jan 24 06:59:47 mi-target-admin systemd[1]: Started krb5-kdc.service - Kerberos 5 Key Distri>
~
lines 1-21/21 (END)
```

Figure 13 - Activation des Services Kerberos

3. Configuration d'un serveur SSH sur la VM target-dmz

L'objectif de cette étape est de préparer le serveur qui recevra les connexions (le serveur d'application) pour qu'il accepte l'authentification Kerberos.



```
GNU nano 7.2 /etc/ssh/sshd_config

# Kerberos options
KerberosAuthentication yes
KerberosOrLocalPasswd no
KerberosTicketCleanup yes
#KerberosGetAFSToken no

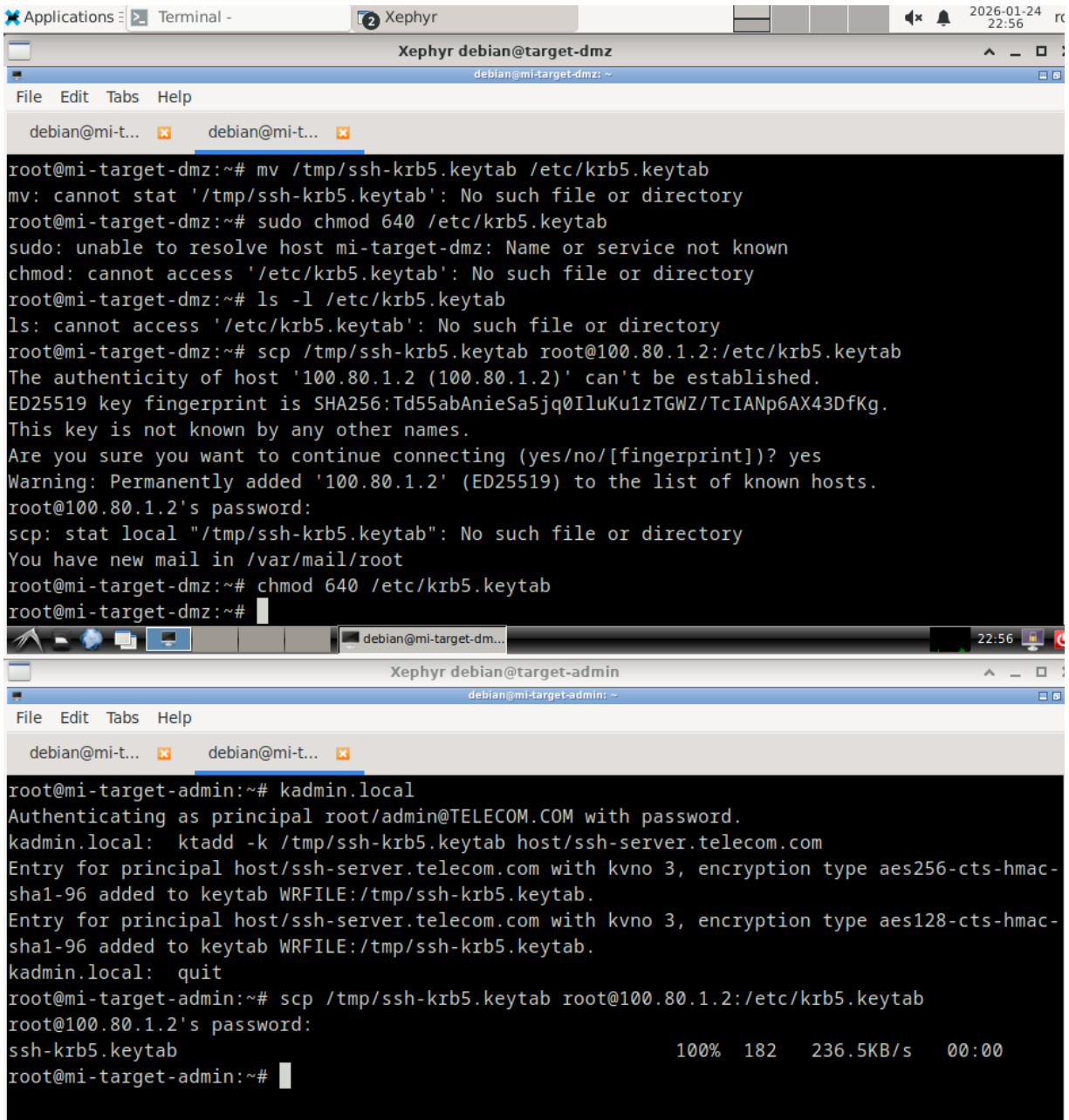
# GSSAPI options
GSSAPIAuthentication yes
GSSAPICleanupCredentials yes
GSSAPIStrictAcceptorCheck no
GSSAPIKeyExchange yes
UsePAM no

^G Help      ^O Write Out  ^W Where Is   ^K Cut        ^T Execute    ^C Location
^X Exit      ^R Read File  ^\ Replace    ^U Paste      ^J Justify    ^_ Go To Line
```

Figure 14 - Configuration du service SSH (DMZ-target)

Nous avons modifié le fichier de configuration du démon SSH `/etc/ssh/sshd_config` sur la machine `target-dmz`. Les directives suivantes ont été activées pour permettre le dialogue avec Kerberos:

- **KerberosAuthentication yes** : Autorise l'authentification via Kerberos.
- **GSSAPIAuthentication yes** : Active l'interface GSSAPI nécessaire pour l'échange de tickets.
- **GSSAPIKeyExchange yes** : Permet l'échange de clés via GSSAPI.



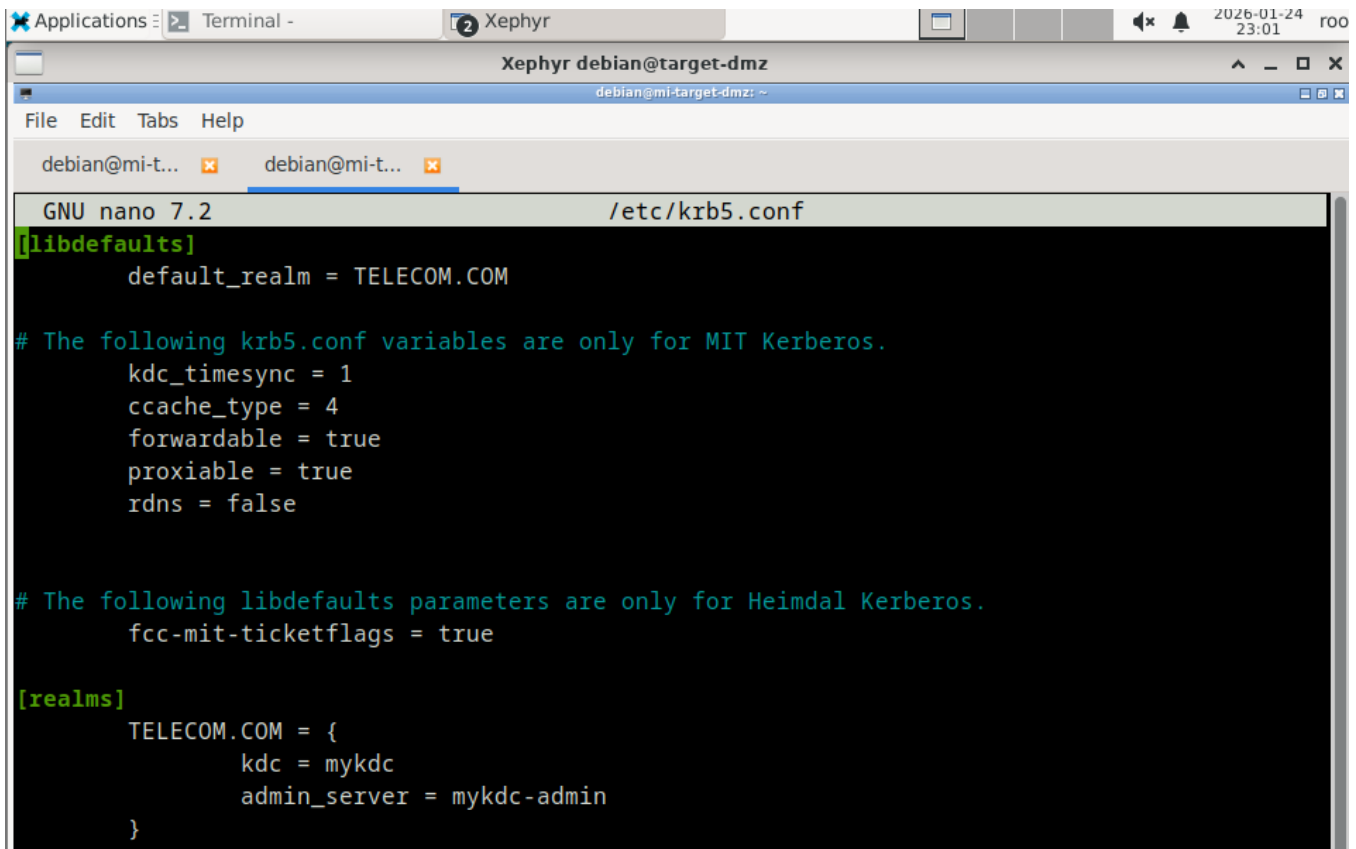
```
root@mi-target-dmz:~# mv /tmp/ssh-krb5.keytab /etc/krb5.keytab
mv: cannot stat '/tmp/ssh-krb5.keytab': No such file or directory
root@mi-target-dmz:~# sudo chmod 640 /etc/krb5.keytab
sudo: unable to resolve host mi-target-dmz: Name or service not known
chmod: cannot access '/etc/krb5.keytab': No such file or directory
root@mi-target-dmz:~# ls -l /etc/krb5.keytab
ls: cannot access '/etc/krb5.keytab': No such file or directory
root@mi-target-dmz:~# scp /tmp/ssh-krb5.keytab root@100.80.1.2:/etc/krb5.keytab
The authenticity of host '100.80.1.2 (100.80.1.2)' can't be established.
ED25519 key fingerprint is SHA256:Td55abAnieSa5jq0IluKu1zTGWZ/TcIANp6AX43DfKg.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '100.80.1.2' (ED25519) to the list of known hosts.
root@100.80.1.2's password:
scp: stat local "/tmp/ssh-krb5.keytab": No such file or directory
You have new mail in /var/mail/root
root@mi-target-dmz:~# chmod 640 /etc/krb5.keytab
root@mi-target-dmz:~#
```

```
root@mi-target-admin:~# kadmin.local
Authenticating as principal root/admin@TELECOM.COM with password.
kadmin.local: ktadd -k /tmp/ssh-krb5.keytab host/ssh-server.telecom.com
Entry for principal host/ssh-server.telecom.com with kvno 3, encryption type aes256-cts-hmac-sha1-96 added to keytab WRFILE:/tmp/ssh-krb5.keytab.
Entry for principal host/ssh-server.telecom.com with kvno 3, encryption type aes128-cts-hmac-sha1-96 added to keytab WRFILE:/tmp/ssh-krb5.keytab.
kadmin.local: quit
root@mi-target-admin:~# scp /tmp/ssh-krb5.keytab root@100.80.1.2:/etc/krb5.keytab
root@100.80.1.2's password:
ssh-krb5.keytab                               100% 182   236.5KB/s   00:00
root@mi-target-admin:~#
```

Figure 15 - Installation du fichier Keytab

Le serveur SSH a besoin de sa propre identité (son "mot de passe") pour déchiffrer les tickets que lui présentent les clients. Ce fichier, généré précédemment sur le KDC, doit être installé localement.

- **Transfert** : Le fichier a été copié depuis le serveur d'administration vers la DMZ via la commande scp.
- **Sécurisation** : Une fois placé dans /etc/krb5.keytab, nous avons restreint ses droits (lecture uniquement pour root, chmod 640) pour éviter qu'un utilisateur non privilégié ne puisse usurper l'identité du serveur.



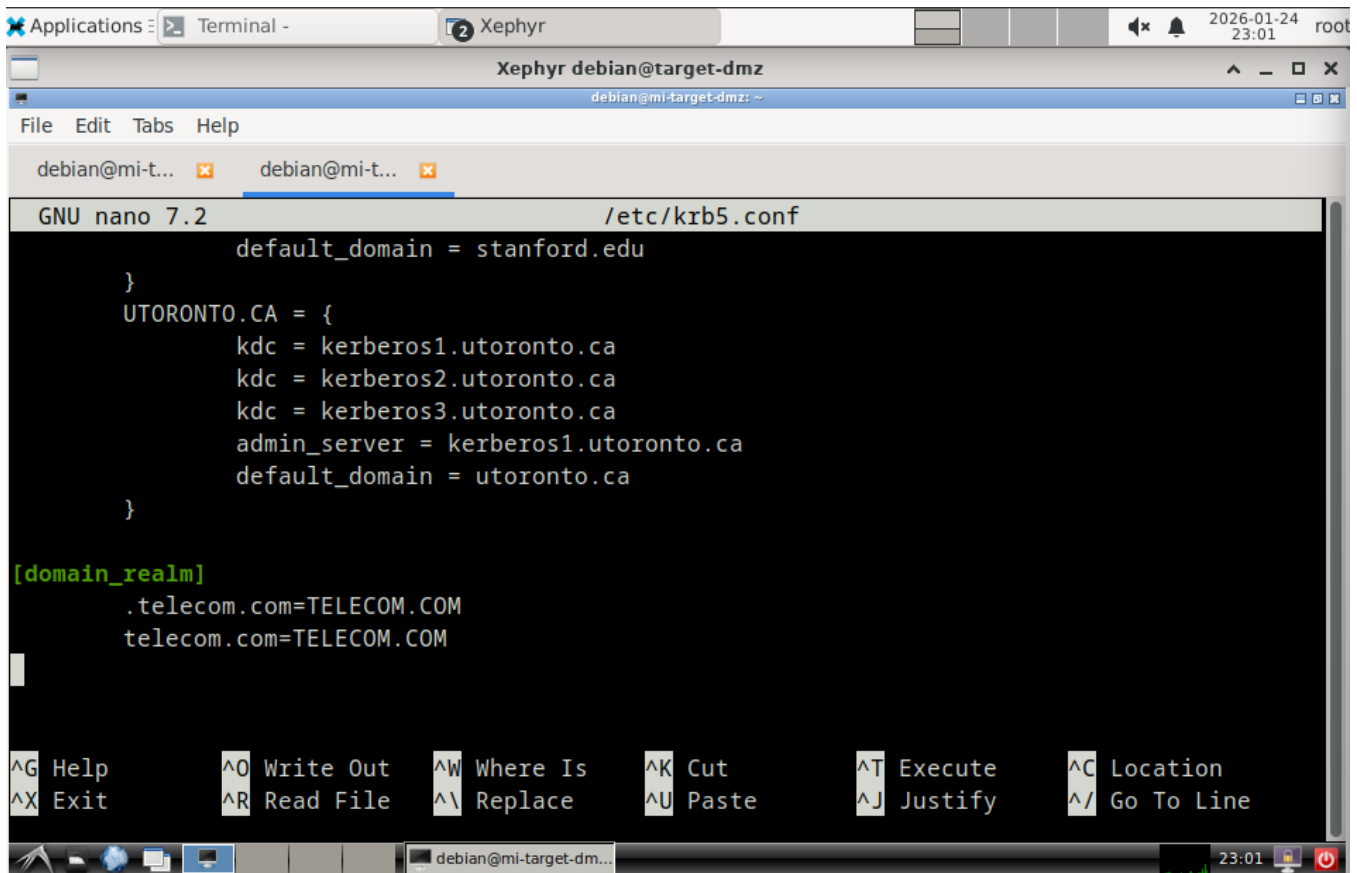
```
GNU nano 7.2 /etc/krb5.conf
[libdefaults]
    default_realm = TELECOM.COM

# The following krb5.conf variables are only for MIT Kerberos.
    kdc_timesync = 1
    ccache_type = 4
    forwardable = true
    proxiable = true
    rdns = false

# The following libdefaults parameters are only for Heimdal Kerberos.
    fcc-mit-ticketflags = true

[realms]
    TELECOM.COM = {
        kdc = mykdc
        admin_server = mykdc-admin
    }
```

Figure 16 - Configuration Kerberos Locale



The screenshot shows a terminal window titled "Xephyr debian@target-dmz" with a root user. The terminal is running the nano text editor to edit the file /etc/krb5.conf. The configuration includes a default domain of stanford.edu, a list of KDCs for the UTORONTO.CA domain (kerberos1.utoronto.ca, kerberos2.utoronto.ca, kerberos3.utoronto.ca), and an admin server at kerberos1.utoronto.ca. Below this, the [domain_realm] section is configured with .telecom.com=TELECOM.COM and telecom.com=TELECOM.COM. The terminal window has a menu bar (File, Edit, Tabs, Help) and a status bar at the bottom showing the time as 23:01 and the user as root.

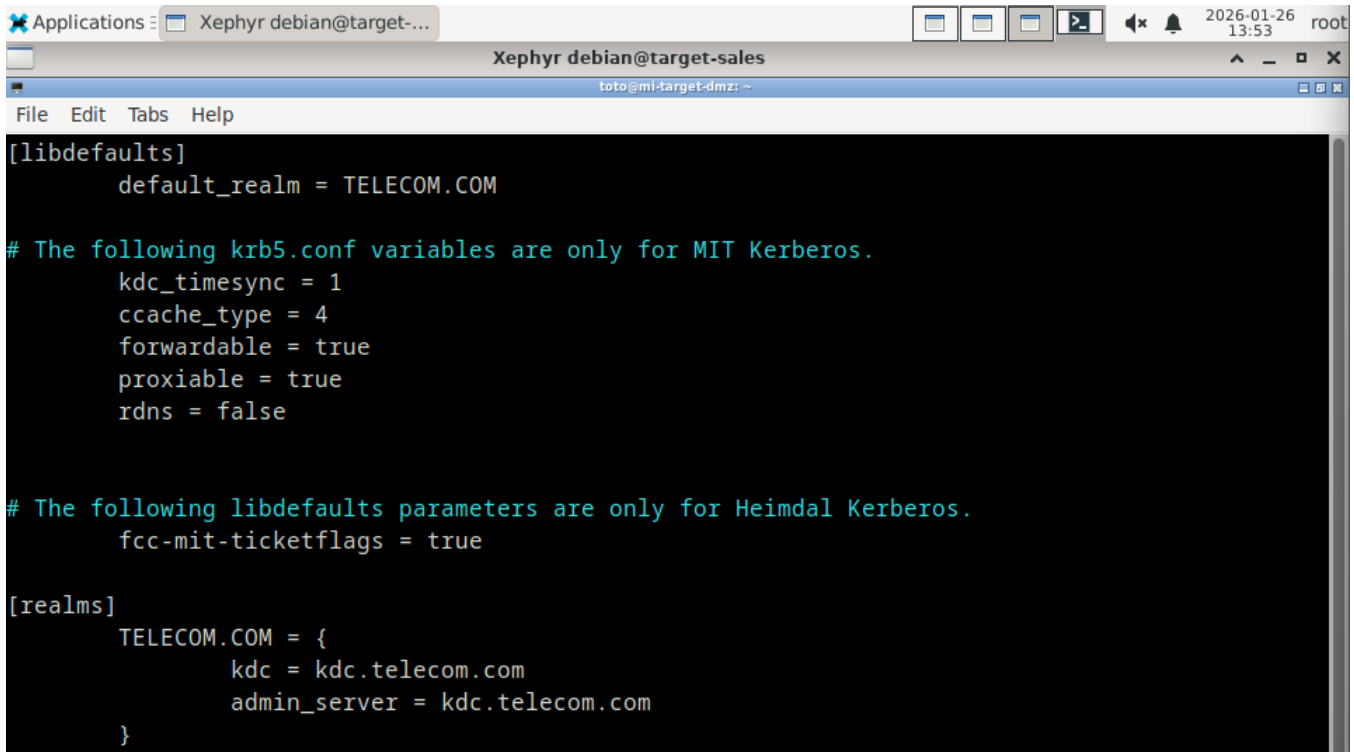
```
GNU nano 7.2 /etc/krb5.conf
    default_domain = stanford.edu
}
    UTORONTO.CA = {
        kdc = kerberos1.utoronto.ca
        kdc = kerberos2.utoronto.ca
        kdc = kerberos3.utoronto.ca
        admin_server = kerberos1.utoronto.ca
        default_domain = utoronto.ca
    }

[domain_realm]
    .telecom.com=TELECOM.COM
    telecom.com=TELECOM.COM
```

Figure 17 - Configuration Kerberos Locale 2

Enfin, nous avons configuré le fichier `/etc/krb5.conf` de la machine `target-dmz` pour lui indiquer quel est son royaume (`TELECOM.COM`) et où trouver le KDC (`mykdc.telecom.com`)

4. Configuration d'un client Kerberos sur une nouvelle VM



```
Applications: Xephyr debian@target-...
Xephyr debian@target-sales
toto@mi-target-dmz: ~
File Edit Tabs Help
[libdefaults]
    default_realm = TELECOM.COM

# The following krb5.conf variables are only for MIT Kerberos.
    kdc_timesync = 1
    ccache_type = 4
    forwardable = true
    proxiable = true
    rdns = false

# The following libdefaults parameters are only for Heimdal Kerberos.
    fcc-mit-ticketflags = true

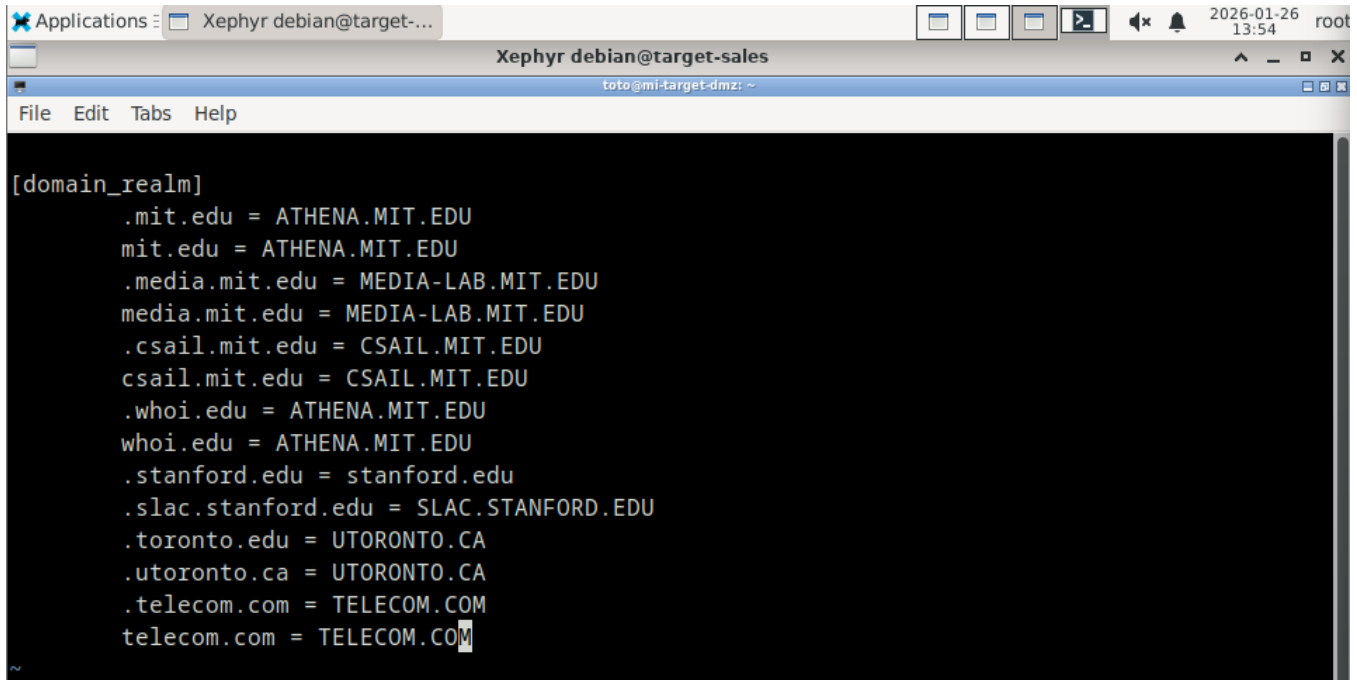
[realms]
    TELECOM.COM = {
        kdc = kdc.telecom.com
        admin_server = kdc.telecom.com
    }
```

Figure 18 - Configuration Client (target-sales)

Nous avons ensuite préparé une machine cliente (target-sales) pour simuler un utilisateur légitime.

Configuration du client : Le fichier `/etc/krb5.conf` a été édité pour définir le royaume par défaut `TELECOM.COM`. Cette configuration permet aux outils clients (comme `kinit` ou `ssh`) de savoir automatiquement quel serveur contacter pour l'authentification.

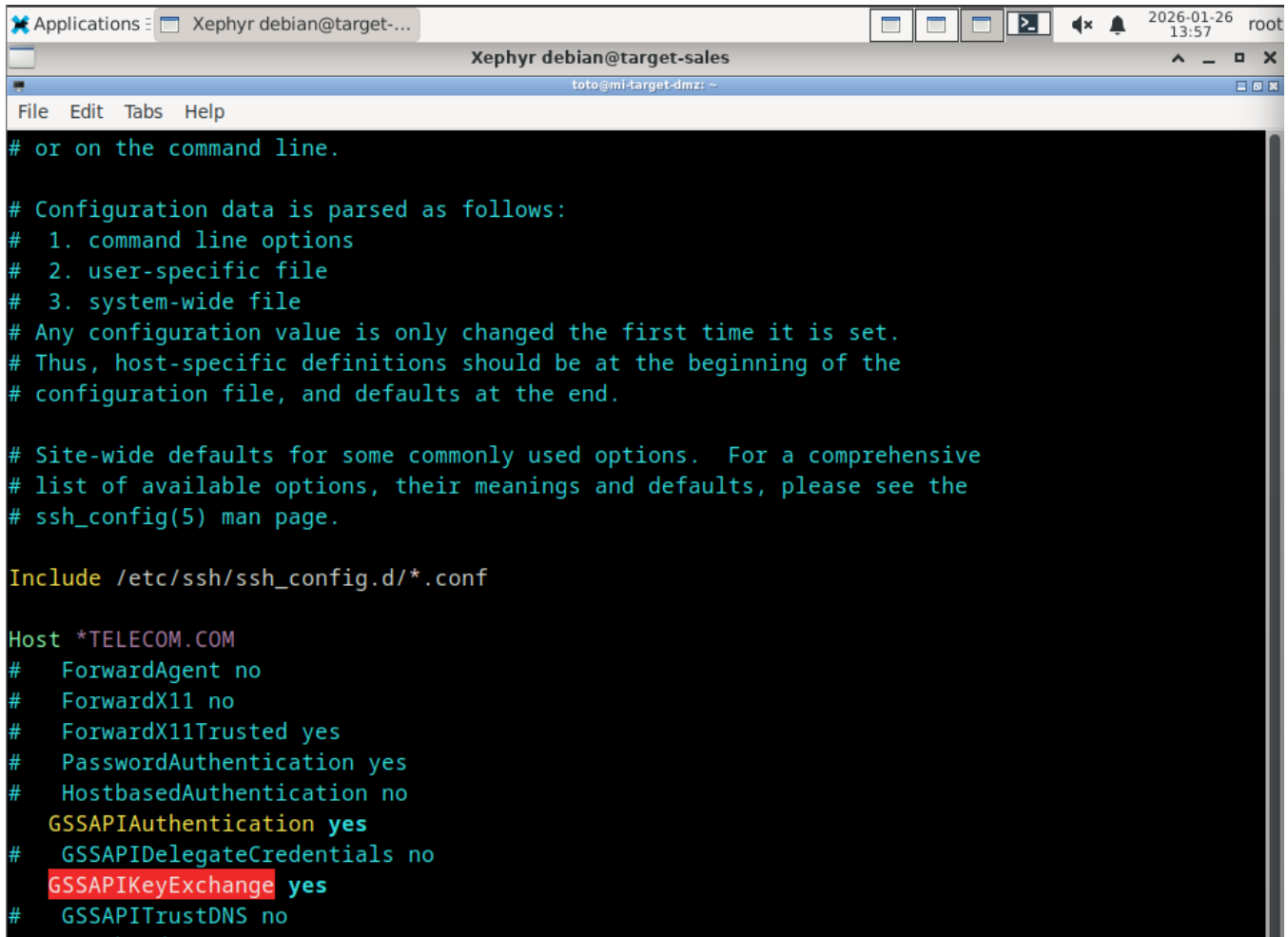
5. Test & Troubleshooting



The screenshot shows a terminal window titled "Xephyr debian@target-sales" with a menu bar (File, Edit, Tabs, Help). The terminal output displays the results of a DNS lookup for the "domain_realm". The output lists several domain mappings, including .mit.edu, .media.mit.edu, .csail.mit.edu, .whois.edu, .stanford.edu, .slac.stanford.edu, .toronto.edu, .utoronto.ca, and .telecom.com, all pointing to their respective hostnames. The terminal prompt is "~".

```
[domain_realm]
.mit.edu = ATHENA.MIT.EDU
mit.edu = ATHENA.MIT.EDU
.media.mit.edu = MEDIA-LAB.MIT.EDU
media.mit.edu = MEDIA-LAB.MIT.EDU
.csail.mit.edu = CSAIL.MIT.EDU
csail.mit.edu = CSAIL.MIT.EDU
.whois.edu = ATHENA.MIT.EDU
whois.edu = ATHENA.MIT.EDU
.stanford.edu = stanford.edu
.slac.stanford.edu = SLAC.STANFORD.EDU
.toronto.edu = UTORONTO.CA
.utoronto.ca = UTORONTO.CA
.telecom.com = TELECOM.COM
telecom.com = TELECOM.COM
```

Figure 19 - Résolution des noms (DNS)



```
# or on the command line.

# Configuration data is parsed as follows:
# 1. command line options
# 2. user-specific file
# 3. system-wide file
# Any configuration value is only changed the first time it is set.
# Thus, host-specific definitions should be at the beginning of the
# configuration file, and defaults at the end.

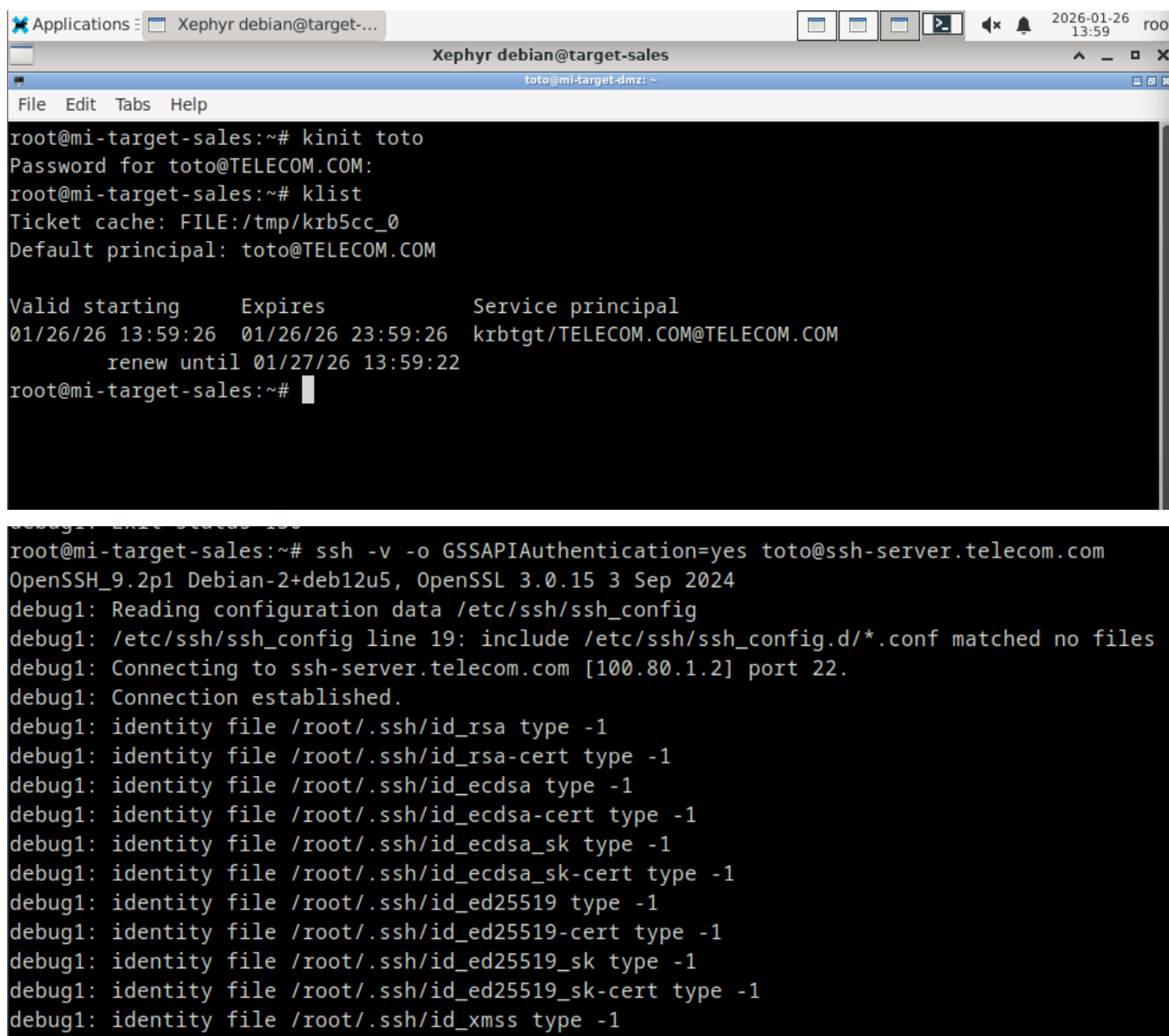
# Site-wide defaults for some commonly used options. For a comprehensive
# list of available options, their meanings and defaults, please see the
# ssh_config(5) man page.

Include /etc/ssh/ssh_config.d/*.conf

Host *TELECOM.COM
# ForwardAgent no
# ForwardX11 no
# ForwardX11Trusted yes
# PasswordAuthentication yes
# HostbasedAuthentication no
GSSAPIAuthentication yes
# GSSAPIDelegateCredentials no
GSSAPIKeyExchange yes
# GSSAPITrustDNS no
```

Figure 20 - Configuration du client SSH

Pour que la commande `ssh` tente automatiquement une authentification Kerberos, nous avons activé l'option `GSSAPIAuthentication yes` dans le fichier de configuration SSH du client



```
Applications ▾ Xephyr debian@target-...
Xephyr debian@target-sales
toto@mi-target-dmz: ~
File Edit Tabs Help

root@mi-target-sales:~# kinit toto
Password for toto@TELECOM.COM:
root@mi-target-sales:~# klist
Ticket cache: FILE:/tmp/krb5cc_0
Default principal: toto@TELECOM.COM

Valid starting      Expires            Service principal
01/26/26 13:59:26  01/26/26 23:59:26  krbtgt/TELECOM.COM@TELECOM.COM
        renew until 01/27/26 13:59:22
root@mi-target-sales:~#

root@mi-target-sales:~# ssh -v -o GSSAPIAuthentication=yes toto@ssh-server.telecom.com
OpenSSH_9.2p1 Debian-2+deb12u5, OpenSSL 3.0.15 3 Sep 2024
debug1: Reading configuration data /etc/ssh/ssh_config
debug1: /etc/ssh/ssh_config line 19: include /etc/ssh/ssh_config.d/*.conf matched no files
debug1: Connecting to ssh-server.telecom.com [100.80.1.2] port 22.
debug1: Connection established.
debug1: identity file /root/.ssh/id_rsa type -1
debug1: identity file /root/.ssh/id_rsa-cert type -1
debug1: identity file /root/.ssh/id_ecdsa type -1
debug1: identity file /root/.ssh/id_ecdsa-cert type -1
debug1: identity file /root/.ssh/id_ecdsa_sk type -1
debug1: identity file /root/.ssh/id_ecdsa_sk-cert type -1
debug1: identity file /root/.ssh/id_ed25519 type -1
debug1: identity file /root/.ssh/id_ed25519-cert type -1
debug1: identity file /root/.ssh/id_ed25519_sk type -1
debug1: identity file /root/.ssh/id_ed25519_sk-cert type -1
debug1: identity file /root/.ssh/id_xmss type -1
```

Figure 21 - Obtention du TGT

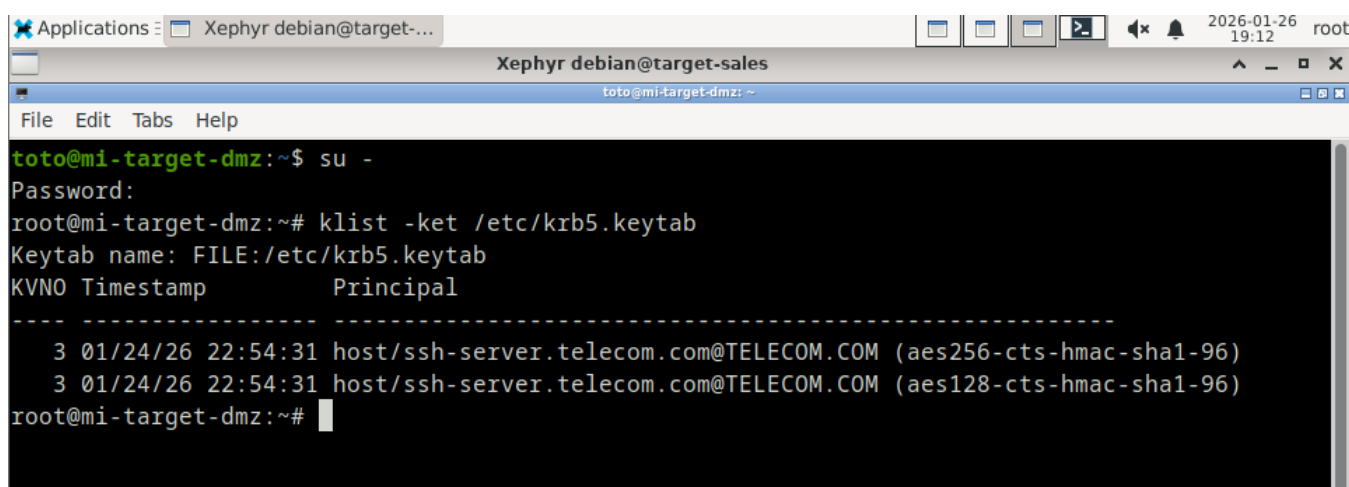
La commande `kinit toto` a réussi, prouvant que le client communique bien avec le KDC. La commande `klist` confirme la présence d'un ticket valide (`krbtgt/TELECOM.COM`).

La commande `ssh -v toto@ssh-server.telecom.com` a permis une connexion sans mot de passe. Les logs de débogage montrent l'utilisation réussie de la méthode `gssapi-with-mic`


```
debug1: client_input_global_request: rtype hostkeys-00@openssh.com want_reply 0
debug1: client_input_hostkeys: searching /root/.ssh/known_hosts for ssh-server.telecom.com / (
none)
debug1: client_input_hostkeys: searching /root/.ssh/known_hosts2 for ssh-server.telecom.com /
(none)
debug1: client_input_hostkeys: hostkeys file /root/.ssh/known_hosts2 does not exist
debug1: client_input_hostkeys: host key found matching a different name/address, skipping User
KnownHostsFile update
debug1: pledge: fork
Linux mi-target-dmz 6.1.0-32-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.129-1 (2025-03-06) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Mon Jan 26 19:05:44 2026 from 100.80.0.2
```



```
Xephyr debian@target-...
Xephyr debian@target-sales
toto@mi-target-dmz: ~
File Edit Tabs Help
toto@mi-target-dmz:~$ su -
Password:
root@mi-target-dmz:~# klist -ket /etc/krb5.keytab
Keytab name: FILE:/etc/krb5.keytab
KVNO Timestamp Principal
-----
3 01/24/26 22:54:31 host/ssh-server.telecom.com@TELECOM.COM (aes256-cts-hmac-sha1-96)
3 01/24/26 22:54:31 host/ssh-server.telecom.com@TELECOM.COM (aes128-cts-hmac-sha1-96)
root@mi-target-dmz:~#
```

Figure 22 - Connection au service

6. Analyse des Messages Kerberos Wireshark

Dans cette partie, et grâce à une capture réseau effectuée sur le client, nous avons pu observer les échanges du protocole Kerberos. Nous avons utilisé Wireshark pour capturer et analyser les échanges protocolaires sur le port 88 (Kerberos). Le scénario a permis d'identifier les phases suivantes :

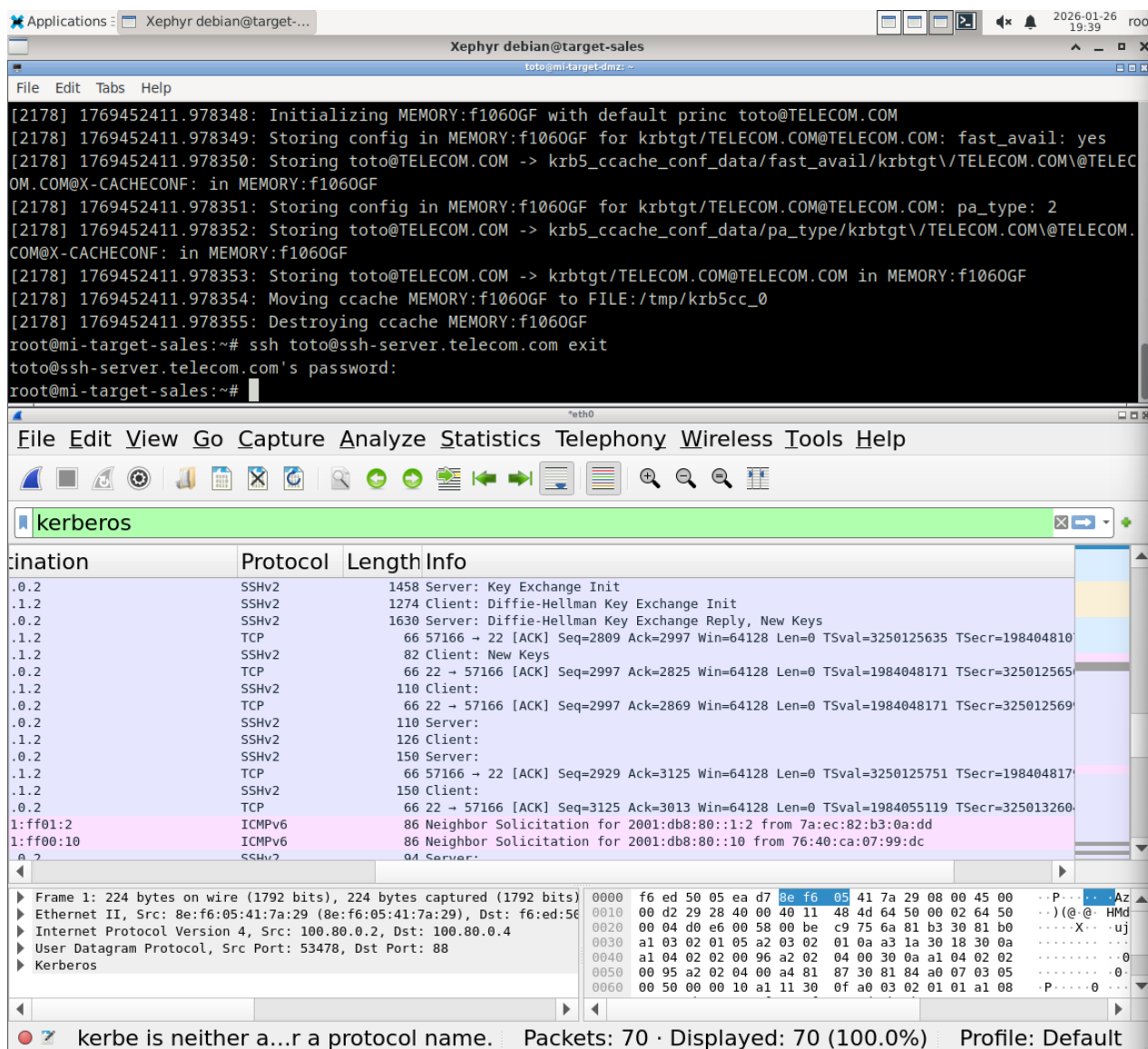
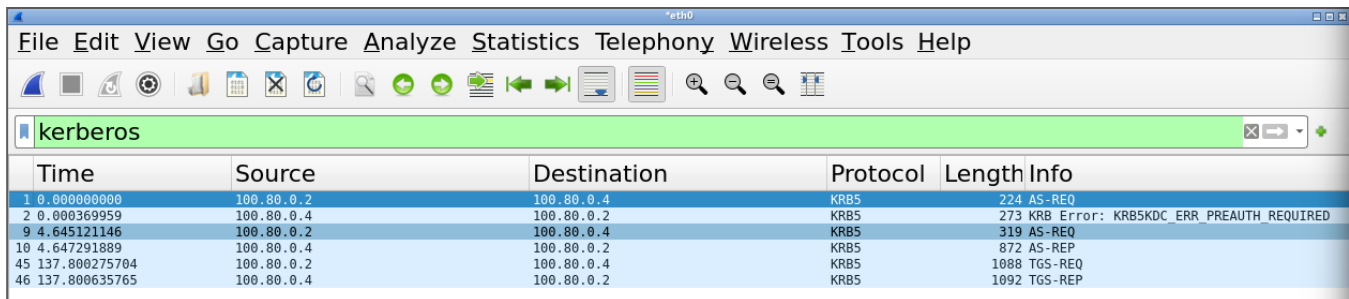


Figure 23 - Capture des message Kerberos Wireshark



Time	Source	Destination	Protocol	Length	Info
1 0.000000000	100.80.0.2	100.80.0.4	KRB5	224	AS-REQ
2 0.000369959	100.80.0.4	100.80.0.2	KRB5	273	KRB Error: KRB5KDC_ERR_PREAUTH_REQUIRED
9 4.645121146	100.80.0.2	100.80.0.4	KRB5	319	AS-REQ
10 4.647291889	100.80.0.4	100.80.0.2	KRB5	872	AS-REP
45 137.800275704	100.80.0.2	100.80.0.4	KRB5	1088	TGS-REQ
46 137.800635765	100.80.0.4	100.80.0.2	KRB5	1092	TGS-REP

Figure 24 - L'analyse des messages Kerberos Wireshark

6.1. Phase d'Authentification (AS - Authentication Service)

- **Commande** : `kinit toto`
- **AS_REQ** : Le client envoie une demande au KDC contenant son nom d'utilisateur et un nonce.
- **AS_REP** : Le KDC vérifie l'identité et renvoie un **TGT** (Ticket Granting Ticket) chiffré avec la clé du KDC, ainsi qu'une clé de session chiffrée avec le mot de passe de l'utilisateur.

6.2. Phase d'Accès au Service (TGS - Ticket Granting Service)

- **Commande** : `ssh ...`
- **TGS_REQ** : Le client présente son TGT au KDC et demande l'accès au service `host/ssh-server.telecom.com`. Il inclut un authentifiant pour prouver qu'il est bien le propriétaire du TGT.
- **TGS_REP** : Le KDC valide la requête et fournit un **Ticket de Service**. Ce ticket sera ensuite transmis par le client au serveur SSH (dans le protocole applicatif) pour prouver son identité.

1. Analyse du message AS_REQ (Demande de ticket initial)

- **Quel est le PVNO dans la requête ? Quel est son rôle ?**
 - **Réponse** : Le PVNO est 5.
 - **Rôle** : Il indique la version du protocole utilisée (Kerberos Version 5).
- **Quels sont les flags activés ? Signification ?**

- **Réponse** : Les flags courants observés sont *Forwardable*, *Proxiabile* et *Renewable*.
- **Signification** :
 - *Forwardable* : Le TGT pourra être utilisé pour obtenir un ticket sur une autre machine (ex: rebond SSH).
 - *Renewable* : Le ticket pourra être renouvelé avant son expiration sans redonner le mot de passe.
- **Quelle est la durée de vie demandée ?**
 - **Réponse** : 24 heures.
 - **Justification** : Le champ till indique 2026-01-27 20:38:25 pour une requête émise le 26 janvier.

2. Analyse du message AS_REP (Réponse du KDC)

- **Est-ce que le PVNO est le même dans la requête ?**
 - **Réponse** : Oui, le PVNO est toujours 5.
- **Quel est le ticket généré ? Son rôle ?**
 - **Réponse** : Le ticket est le **TGT** (Ticket Granting Ticket) pour le service krbtgt/TELECOM.COM.
 - **Rôle** : Il sert de "passe-partout" temporaire. Le client le présentera au KDC pour obtenir d'autres tickets de service sans avoir à ressaisir son mot de passe.
- **Par quel algorithme le challenge est-il chiffré ?**
 - **Réponse** : aes256-cts-hmac-sha1-96.
 - **Mode opératoire** : AES en mode **CTS** (Cipher Text Stealing).

3. Analyse du message TGS_REQ (Demande d'accès au service)

- **Quel service est demandé ?**
 - **Réponse** : host/ssh-server.telecom.com.
- **Quel est le rôle du champ authenticator ?**
 - **Réponse** : Il contient un timestamp chiffré avec la clé de session du client. Il prouve au KDC que l'utilisateur est bien le propriétaire légitime du TGT (protection contre le vol de ticket et le rejeu).

- Quel ticket est utilisé dans la requête ?

- **Réponse** : Le **TGT** (obtenu lors de l'échange AS précédent).

4. Analyse du message TGS_REP (Ticket final)

- Quel est le ticket de service fourni ?

- **Réponse** : Un ticket de service spécifiquement pour le serveur SSH (host/ssh-server...). Ce ticket est chiffré avec la clé du serveur (celle contenue dans le fichier Keytab).

- Quelle est la "Session Key" associée au service ?

- **Réponse** : C'est une clé unique générée par le KDC, qui servira à chiffrer les échanges ultérieurs entre le client toto et le serveur SSH.